

הנדסה לאחור תשפ"ו סמסטר אביב : גרסה 438.0

מטלות הגשה 1 ו2 (א2,ב2). (ממוקד ומקוצר)

בכל פניה והגשה בקשר למטלה בבקשה לפרט את השמות וכול הפרטים (כולל טלפון) של כול חברי הצוות וגם של הפונה בגוף המייל. ובכותרת לרשום: RCE2026B + שמות בני הזוג כולל תז.

המטרה : ללמוד מדו"חות מחקר תוך שילוב מקורות ובחינה ביקורתית (למשל דו"ח ראשוני מול דו"ח מאוחר, דו"ח טכני מעמיק מול דו"ח פחות טכני, גרסה מתקדמת מול גרסה מוקדמת) .

מענה בשפה העברית או האנגלית (אפשר חברי צוות מקבוצות שונות) (שאלות ודרישות המטלה בגרסה העברית ובגרסה האנגלית זהות).

לחילופין: כתחליף למטלות : ניתן לפנות לבקש או להציע נושא חליפי או רעיון מחקר או מטלת מחקר או ניתוח פרוטוקול או תיאור ניתוח חולשה (תוך שימוש ב שילוב של IDA PRO או windbg i gHidra או קריאת מאמרים) או נושא אחר מתחום הקורס.(ועבורו יהיו דגשים שונים ושאלות שונות) (למשל: נושאי תקיפת מערכות AI , ניתוח חולשות ב iPhone IOS ועד)

מומלץ על סעיפים שמוגדרים "אופציונאלי" (ואפשר בהחלט לדלג עליהם ואין חובה להגישם!) : לקרוא ולהבין את תפקיד השאלה, לו כן הייתם צריכים לענות עליה (במטלה זו או בראיון עבודה עתידי או כצורת חשיבה וגישה. ידיעת השאלות הינה צעד ראשון בהבנה, גם בלי תשובות).

לכל מטלה : (1 ו 2) יש להגיש : (בבקשה רק באימייל, ולא ב DRIVE! אפשר לפצל למספר שליחות)

1 (מסמך WORD ובו עבודת ההגשה (אין צורך במצגת) (אפשר בעברית או באנגלית.)

2 רשימת מאמרים (אפשר בקובץ word) רשימת בלוגים והפניות לציוצי טוויטר וסרטוני YOUTUBE .

3 העתק מלא PDF או הדפס ל PDF או העתק-הדבק של תוכן המאמרים כולל שירטוטים כל מאמר בנפרד,

(או צילום מסך מלא, כולל גלילה של המאמרים החשובים ,או הדפסה ל PDF מתוך הדפדפן) ,

אפשר בקובץ נפרד RAR/ZIP ובו ריכוז המאמרים. אפשר גם לשלוח במיילים נוספים נפרדים.

כללית במטלה הראשונה: יש לבחור נזקה ולענות על השאלות ע"פ מאמרים של חוקרים אחרים.

לא צריך לנתח נזקות לבד (ובבקשה לא להדביק לעצמכם, בבית או בעבודה או במכון, את המחשב בנוזקותכן ניתן לנסות לעלות העתק נזקה לשירותי ניתוח בענן דוגמת any.run או hybrid-anlysis.com)

צריך לקרוא את המאמרים בצורה ביקורתית: יש לכלול ולהצביע על מאמרים מוקדמים ומאמרים בולטים מאוחרים. (להעריך עדכניות ומידת פרוט ואיכות) ובפרט לאתר מאמרים טכניים מעמיקים ועדכניים (כיסוי רחב או העמקה בנקודה טכנית מסוימת). לעיתים ידרשו כמה מאמרים להשלמת התמונה. (כי אולי מאמרים שונים יכסו נקודות מבט שונות ומנגנונים שונים אבל לא את כולם או תתי גרסאות שונות של אותה נזקה או משפחה של נזקות)

בפרט מומלץ לבדוק האם יש מאמרים חדשים ולהצביע גם על המאמרים המעמיקים ביותר. חשוב למצוא ולהצביע על מאמר מפורט ועדכני .

כל סעיף או פרק אשר מסומן בו " (אופציונאלי) " הוא אינו חובה ואפשר לדלג עליו.

מטלה עיקרית (גדולה 80%) מטלת הגשה 1: " נזקות מורכבות (נזקה אחת או משפחה) "
מטלה שניה: (קטנה 20%) מטלת הגשה 2 : "מציאת קוד מקור בשפה עילית : נזקה או RAT או POC או CrimeKit או Exploit Kit <u>שקוד המקור שלהם דלף</u> <u>וזמן</u> ומאמרי ניתוח שלהם קיימים" (דלף: הכוונה- זמן, נחשף , פורסם, נגנב ופורסם , התגלה "במקרה" "נפל ממשאית " וכו . באנגלית: " Leaked ")

בנוסף יש להגיש **בנופרד צילום מסך מלא** או **העתק** של כל המאמרים הרלוונטיים. **כל מאמר בקובץ נפרד**. (לא די ב URL כי אתרים נקנים ומאמרים נעלמים או מאחורי PayWall כלומר חומות תשלום) או ב PDF מקורי או אופצית הדפסה מתוך הדפדפן את פלט שהוא קובץ PDF (בחירה בשלב בחירת המדפסת לאחר הפעלת כפתור הדפסה בתוך הדפדפן) ואו ע"י צילום המסך **המלא** הקיים בדפדפן FireFOX תפריט ימני באיזור לבן בעזרת TakeScreenShot או אופצית ה Save i WebCapture בדפדפן Edge. (הערה: שמירת דפי Web בצורת Html מקומית אינה טובה כי כוללת קוד ב JavaScript שפונה החוצה ואינה מהווה העתק מדויק בר שיחזור) **או ע"י אופצית הדפסה ל קובץ PDF בתפריט בחבירת מדפסת בעת הדפסה בדפדפן.** (הצורך לשמור מאמרים: כי יש מאמרים שנעלמים או משתנים או שהגישה דרך הרשמה ואו לעיתים הם מתעדכנים או כי יש מאמרים שיש לגשת אליהם דרך הספרייה והגישה תחסם בסיום התואר ולעיתים יש מאמרים שגויים טכנית או שמפורסמים בתור מסע-דיסאינפורמציה שנעלמים או מתוקנים לאחר מכן).

על צילומי המסך להיות קריאים וברורים ומלאים (כול המאמר) (לא העתקות או צילום חלקי. יש להגיש בבקשה רק מסמכי PDF או MSWORD או צילומי מסך מלאים של כל המאמר).

הערה: כאשר יש לינק למסמך והלינק שבור (כלומר כבר לא ניתן לגשת ללינק שבעבר עבד) לעיתים ניתן לגשת למסמכים שנעלמו ע"י שימוש ב WayBack Machine או ב archive.org

מדיניות שימוש בכלי AI : שימוש בכלי AI ותרגום אוטומטי. (מותר, מומלץ אבל יש חובת איזכור של הפרומט ושל התשובה כולל סידרת הפרומטים עד לשיפור. יש גם לציין את הכלי AI וגרסתו, ומומלץ להשוות תשובות בין כלים שונים. ההשוואה, איתור מקורות וקריאה ביקורתית באחריות אנושית)

מותר להעזר בכלי AI, אבל יש לציין את הפרומפטים בהם השתמשתם ובאחריותכם לבדוק נכונות התשובות, העובדות, ההפניות והציטוטים. להיזהר מהפניות למקורות לא קיימים. יש להפעיל חשיבה ביקורתית ולחפש הסברים טכניים מעמיקים ויסודיים (לפחות למנגנון אחד) במקרה שימוש בתרגומים אוטומטיים יש להקפיד על מונחים מקצועיים ולא תרגום ישיר כפשוטו.

יש גם לצרף את גם את צילומי המסך של כל הפרומפטים ושל התשובות הגולמיות הבסיסיות מהמערכת (וגם העתקי טקסט של התשובות) (למרות שיעברו עידכון ועריכה אנושית לאחר מכן ...) יש חובת אחריות אנושית: בדיקת אמיתות מקורות (עקב נטיה ל"הזייה" ו"המצאות" ע"י ChatGPT).

מומלץ גם להעזר מאגרי המידע בספרייה עבור מאמרים אקדמיים. (בקורס זה: לא בעדיפות ראשונה) נושא המטלה הראשונה בסמסטר זה: **נוזקה עם מספר מרכיבים ואו נוזקה מודולרית.**

למטלה עיקרית 1: יש לבחור "נוזקה מורכבת רצוי עם עם רכיבים מודולריים" או "רבת שלבים" כנושא למטלה הראשונה ואז לענות על שאלות מובנות (ע"י מציאת מאמרים).

למטלה קטנה 2: יש לבחור "נוזקה אחרת" (**או RAT או POC או CrimeKit** או Exploit Kit או כלי תקיפה) שקוד המקור שלהם "דלף ונגיש ברשת" וגם יש מאמרי ניתוח ביחס לנוזקה ולקוד שדלף וגם הפניה לקוד מקור של POC או Exploit code (אבל לא בתצורת קוד בינארי בלבד).

הערות פרודצורליות:

אופציונאלי, לא חובה: רצוי לשלוח מייל ל sre2025asre@gmail.com ובו תיאור נושא הנוזקה מראש ושמות חברי הצוות. צוותים בהם יש מילואימניקים או כוחות ביטחון: יקבלו הקלות. לעדכן בכל מקרה של עיכוב. לא יורדות נקודות על איחור מאושר.

אפשר גם לקבל אישור למטלות חליפיות (נושא רלונטי בסייבר, מחקר נוזקות או מחקר חולשות או הסבר על דרכי גילוי חולשה בדפדפנים או בקרנל או דרכי ניצול חולשה בדפדפן מסוים או בקרנל או מחקר פרוטוקולי תקשורת או תקיפת מערכות AI כולל JailBreaks : למי שחקר או רוצה לחקור אחרת). (לא להסס לפנות/לטלפן-אישית-מיידית לתאר ולבקש).

חשוב בהקדם : בבקשה לעדכן במייל sre2025asre@gmail.com את נושא הנוזקה ואו נושאי העבודה שנבחרו + שמות כל חברי הצוות+תז+טלפונים, והיום בשבוע והשעה של קבוצת ההרצאה אליה כול בן-זוג רשום + פרטי קשר כולל שם מלא בעברית ובאנגלית וגם כמו שרשום בעמדת מידע + תז שם טלפון ומייל של כול השותפים בצוות.(אפשר לערב בני זוג מקבוצות שונות) בכל מקרה של קושי , בבקשה **לטלפן** לסגל הקורס (למשל למרדכי בנייד, שיחה קולית או סמס) להיזהר ובבקשה לא לבחור נוזקות פשוטות מידי (לדוגמה : לא I love you Virus וגם לא malisa)

בכל פניה והגשה בקשר למטלה בבקשה לפרט את השמות וכול הפרטים של כול חברי הצוות וגם של הפונה. ובכותרת לרשום: RCE2026B + שמות בני הזוג כולל תז .

	שם מלא בעברית כמו שרשום בעמדת מידע	שם מלא באנגלית	תז:	מייל:	נייד:
מגיש 1					
מגיש 2					
מגיש 3					

בכל פניה בבקשה יש לציין גם **בשורת הנושא של** המייל ולפרט את שמות חברי הצוות ותז.וטלפונים לקשר.

נא לשנות את שורת הנושא Subject של הודעת הדוא"ל כך שתכלול את שמכם ושמות השותפים. (בפרוט שם +תז ובכותרת ובגוף ההודעה פרוט גם של : שם+תז+טלפון+מייל של המגישים)

מועד הגשה: ה **24 /June/ 2026** למייל sre2025asre@gmail.com (למי שיש קושי עם המועד מוזמן לפנות ולהודיענו,נקל ונתחשב, לחילופין מי שזקוק לפרסום ציון מוקדם יותר אזי כמובן מוזמן להקדים ולבקש להקדים את הציון.) (אפשר לפנות טלפונית או במייל כדי לקבל הארכה) הגשות : בזוגות או בשלושות: (אפשר גם בבודדים, לפנות להקלות) (בבקשה לפנות על כל שאלה)

הגשה במייל. אפשר דחוס עי winzip או rar . (או מפוצל בין כמה שליחות)

בבקשה את המסמך העיקרי:רק בפורמט DOCX או ODT.לא להגיש ב PDF!

בבקשה לא להגיש ב dropbox ולא להגיש ב google-drive .רק באי-מייל !

(את המאמרים יש לשמור **בקובץ נפרד לכל מאמר**, צילום מסך מלא או הדפסה מתוך הדפדפן למסמך PDF ואת אוסף צילומי המאמרים ניתן להגיש ב ZIP אחד גדול של תיקיה,או מחולק לחלקים) ניקוד לא אחיד לסעיפים. בציון תהיה התחשבות בניתוח של נוזקות וקיימים מורכבים במיוחד .

(תהיה הקלה בדרישות כי בקיימים , במתקפות או נוזקות מורכבות עבודה מלאה ומפורטת עשויה לכלול ספר עבה במיוחד...ואתם לא נדרשים לזה.)

אתם מוזמנים לפרט בקצרה גם על נוזקות שבחנתם ושבסוף החלטתם לא לכתוב עליהן כי בחרתם בנוזקה אחרת. (נעניק נקודות גם על מאמצים מוקדמים) (רצוי להוסיף רשימה נפרדת של מאמרים ראשוניים אותם בחנתם, גם אם בחרתם להסתמך על מאמרים אחרים).

בכל מקרה של אי בהירות או דרישות שנראות מורכבות מידי : אתה מוזמנים ליצור קשר (גם בחג ולטלפן שיחה קולית!) כי לא כל הסעיפים רלוונטים לכל הנוזקות . ולעיתים לא לכל השאלות מופיעות תשובות במחקרים.(ואז תקבלו הקלה) .

מטלה 1 :

יש לבחור נוזקה מורכבת או עם מספר תתי-רכיבים, רצוי בעלת מרכיבים מודולריים, ולפרט עליה כנדרש.

העדיפות היא **נוזקה ששימשה כבסיס ואו** כחלק ממסע רחב או לחילופין כלי טכנולוגי מתקדם. אפשר לבחור גם נוזקה ששימשה בהתקפה בודדת רבת חשיבות על גוף בודד בעדיפות למתקפה בעלת פוטנציאל פיננסי ישיר. לחילופין אפשר גם לבחור משפחה של **כלים ליצירת נוזקות** מהתחום הפיננסי או CrimeKit. כמובן רצוי תוכנה מורכבת עם מספר מודולים או שפת סקריפטים פנימית. (לפרט על השפה הפנימית ועל מודולים נוספים להרחבה באם ידוע עליהם)

בבחירה מומלץ וכדאי לבחור **נוזקה מורכבת ומתוחכמת** להבדיל מנוזקה פשוטה !

במטלה מספר חלקים : (כאן רשימת כותרות, לכל כותרת יש גם פירוט רחב בהמשך)

(1) רשימת מקורות ומאמרים (אפשר לצרף רשימה+לינקים בסוף המסמך ובנוסף גם קובץ RAR או ZIP נפרדים, ובהם גם צילומים או העתקי PDF של כל המאמרים)

(2) (אופציונאלי) התייחסות היסטורית ורקע כללי.

(3) פרוט טכני (כללי)

(4) פרוט טכני (רצוי פרטני) על הנוזקה (בדגש: מנגנונים פנימיים).

(5) (אופציונאלי, רצוי התייחסות מצומצמת) פרוט טכני (רצוי פרטני) של מערכי הפצה ושליטה ופיקוד (אם ידוע) בסדרות תקיפה עיקריות. (כי יתכן שהנוזקה מופצת במספר ערוצים שונים)

(6) (אופציונאלי) אם ידוע: פרוט כללי וטכני ביחס לקבוצה מאחורי הנוזקה ושיטות וכלים דומים בהם היא משתמשת (שרתים, תוכנות, TTPs שמאפיינים אותה ואו מאפשרים את זיהוייה או את הקישור אליה).

(7) (אופציונאלי) התייחסות ל"סוף הסרט": מידע עדכני וחדשות אחרונות מהתקופה האחרונה בנוגע לנוזקה או למי שכתב אותה.

(8) (אופציונאלי) התייחסות כלכלית: גם לנזקים, גם לעלות הפיתוח (אופציונאלי)

(9) חשוב: (!) **בתמציתיות: פרוט טכני קצר על ה CVEs ואו החולשות עליהן מתבססת הנוזקה.**

(10) (אופציונאלי ולא נדרש!) ניתוח הנוזקה ואופן פעולתה ע"פ MITRE ATT&CK Framework

ומיפוי בהתאם ל Cyber Kill Chain של לוקהיד מרטין

(11) בהיקף קטן: **ללא קשר לנוזקה שנבחרה**: לחפש חולשה ע"פ מספר CVE מהתקופה האחרונה באתר cve.org או מפרסומים אחרים

(12) בהיקף קטן: **ללא קשר לנוזקה שנבחרה**: לבחור שני מנגנונים טכניים למניעה, הגנה או למיטיגציה ולהוסיף תאור מצומצם בקצרה ע"פ הרשימה שב <https://d3fend.mitre.org>

(13) בהיקף קטן: לאתר שם של קבוצת תקיפה סינית ולפרט עליה.

(14) בהיקף קטן: לאתר שם נוזקה ל Mac OS Malware : (מערכת הפעלה של מחשבי (APPLE

(15) **ללא קשר לנוזקה שנבחרה**: לתאר מנגנון טכני שנוזקות משתמשות בו מסוג (BYOVD) Bring Your Own Vulnerable Device-Drive ולאתר מאמרים שמתארים את המנגנון.

(הקלה לסמסטר זה: נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון. וציון שמות CVE.

16) (אופציונאלי) ללא קשר לנוזקה שנבחרה : לבחור **מנגנון טכני** אחר שונה נוסף מהמתואר מעלה שנוזקות משתמשות בו (או תת-מנגנון טכני) ולאחר מאמרים שמתארים את המנגנון .

(הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון.

17) ללא קשר לנוזקה שנבחרה : לבחור **מנגנון להגנה שמערכות מיחשוב משתמשות בו** ולאחר

מאמרים שמתארים את המנגנון -חלק מהמאמרים מוזכרים באתר Mitre D3fend

ב : <https://d3fend.mitre.org/> בדגש על Detect-->Process Analysis

(הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון.

18) ללא קשר לנוזקה שנבחרה : לבחור **מנגנון טכני** שנוזקות משתמשות בו לצורך Anti Debug

(תת-מנגנון טכני) אפשר מתוך הרשימה שב: <https://anti-debug.checkpoint.com>

ולאחר מאמרים שמתארים את המנגנון -חלק מהמאמרים מוזכרים באתר לעיל או Mitre ATT&CK

(הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון.

19) בהיקף קטן: ללא קשר לנוזקה שנבחרה : לבחור **מנגנון טכני** שנוזקות משתמשות בו לצורך

Privilege Escalation ע"פ המתואר ב Mitre ATT&CK Enterprise Matrix

(תת-מנגנון טכני) אפשר מתוך הרשימה שב: <https://attack.mitre.org/tactics/TA0004>

ונדרש רק לאתר מאמרים שמתארים את המנגנון (ברמת פרוצדורה) .

(הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון ופרוט שם מאמר.

20) בהיקף קטן: להביא דוגמה למקרה של החדרת נזקה ב Supply chain attacks

<https://docs.microsoft.com/en-us/windows/security/threat-protection/intelligence/supply-chain-malware>

21) בהיקף קטן: להביא דוגמה למודול RAT פופולארי ולציין שמות נזקות או קבוצות תקיפה שנעזרות בו .

22) בהיקף קטן: מציאת שם נזקה שמשתמשת בשיטות של fileLess Malware

23) בהיקף קטן: תיאור נזקה שמשתמשת ב WebInject

24) בקצרה: איתור מידע על מתקפה או חולשה שקשורה למערכת AI .

25) בקצרה: איתור מידע על מתקפה או נזקה שנעזרת ב יכולות AI או מערכת AI מרוחקת.

26) בקצרה: איתור מידע על קבוצת תקיפה אירנית בסייבר. שפעילה בתקופה האחרונה.

27) אופציונאלי: בהיקף קטן: היכרות עם שיטות הזרקת קוד ב MSWindows

28) שימוש בכלי AI: שימוש ב ChatGPT או www.perplexity.ai ואו גימיני או קלוד לצורך

מענה נוסף על אחת השאלות לעיל 12-25 (בנוסף או בהשלמה למענה אנושי ,

אבל באחריות אנושית) ממולץ גם לצרף שירטוטים ודיאגרמות והסברים טכניים.

או אופציונאלי: Amazon Q Developer

(29) בהיקף קטן: לאתר שם חולשה בה לIPHONE : IOS vulnerability (מערכת הפעלה של Iphone)

(30) הסבר קצר של שיטה אחת/ טכניקה להשגת "הישארות בתוך המערכת" Persistence ע"פ [/https://attack.mitre.org/tactics/TA0003](https://attack.mitre.org/tactics/TA0003)

(31) הסבר קצר של שיטה אחת/ טכניקה לביצוע "סילום זכויות מקומיות" Local Privilege Escalation ע"פ [/https://attack.mitre.org/tactics/TA0004](https://attack.mitre.org/tactics/TA0004)

(32) הסבר קצר של שיטה אחת/ טכניקה לביצוע "תנועה רוחבית" Lateral Movement ע"פ [/https://attack.mitre.org/tactics/TA0008](https://attack.mitre.org/tactics/TA0008)

(33) הסבר קצר של שיטה אחת/ טכניקה לביצוע "הוצאת מידע" Exfiltration ע"פ [/https://attack.mitre.org/tactics/TA0010](https://attack.mitre.org/tactics/TA0010)

(34) הסבר קצר של שלב אחד מבין השלבים של 7 stages of the Lockheed Martin kill Chain ע"פ https://www.splunk.com/en_us/blog/learn/cyber-kill-chains.html

(35) (אופציונאלי) הסבר מהו CVSS ובפרט מהם ההבדלים בין גרסאות 3.0 3.1 ו 4

(36) (אופציונאלי) מה החידוש במודל Cyber COBRA של לוקהיד מרטין בקצרה מה החידוש ומה היתרון בשימוש של -Contextual-OBjective-Rating CYBER COBRA על פני Model

Lockheed Martin kill Chain ומה ההבדל בין ניתוח עפ CVSS לבין Cyber Cobra [https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Contextual-OBjective-Rating\(COBRA\)_FINAL.pdf](https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Contextual-OBjective-Rating(COBRA)_FINAL.pdf)

COBRA evaluates the overall severity of cyber exploitation based on the context (circumstances, setting, conditions) in which the discovered findings reside. This helps to reveal an environment's resiliency to a cyber-attack and provides countermeasures based on this data.

1) רשימת מקורות ומאמרים (אפשר בסוף) וצילומי מאמרים

יש לצרף רשימת מקורות ומאמרים (אפשר לצרף רשימה+לינקים בסוף המסמך תשובות) ובנוסף גם קובץ ZIP או RAR נפרדים, ובהם גם צילומים או העתקי PDF של כל המאמרים.

יש לצרף רשימת מאמרים בתוך המסמך כולל לינקים.

יש לצרף מסמכי PDF או העתקת Copy Paste לתוך מסמך Doc נפרד כולל צילומי מסך מלאים או שמירת דפי Web עי הדפסה לקובץ Pdf (במקום הדפסה למדפסת רגילה).

(אפשר לפצל שליחה למיילים נפרדים) אבל אין לצרף צילומי מאמרים לתוך המסמך העיקרי אלא למסמכים נפרדים.

פרוט: יש לצרף רשימת מאמרים ובלוגים והפניות טוטר ולינקים אליהם הכוללים ניתוחים: יש להכין ולהגיש רשימה וברשימה לכלול רשימת בלוגים ורשימת מאמרים שמנתחים את הבעיה ואו הנושא. גם מאמרים ומבלוגים של חברות אנטי וירוס וגורמים אחרים (אם אין הורדה כמסמך WORD ואו PDF אז כדאי לבצע שמירה שלהם ע"י צילום מסך מלא כולל גלילה מטה שמתבצעת אוטומטית ב FIREFOX או העתק הדבק למסמך WORD כולל לינקים למקור או הדפסה בדפדפן למסמך PDF).

(אופציונאלי:) ארגון רשימה רצוי ע"פ TIMELINE. (ניתוח על ציר הזמן לצורך הצבעה על מאמרים מוקדמים, שלרוב פחות עדכניים ומאמרים מאוחרים שלעיתים מסבירים הרבה יותר לעומק).

יש גם לכלול ברשימה מאמרים שכוללים רשימות של נוזקות (URL+והפניה+צילום מסך) אשר נעזרתם בהם כדי לבחור את הנוזקה הספיציפית ואו הכלי ליצירת נוזקות.

(כאן כדאי להעזר בדוחות סיכום ודוחות מגמה שנתיים ורבעוניים של חברות אבטחה)

יש לשמור ולצרף העתק של כול המאמרים הרלוונטים (רצוי בקובץ דחוס נפרד אחד או יותר).

(אופציונאלי:) רצוי לצרף גם רשימת **שמות חוקרים מובילים** שהתייחסו לנוזקה זו.

מומלץ מאוד לצרף צילום מסך של רשימת מאמרים עדכניים (גם אם בוחרים להשתמש רק בחלק קטן ממנה ואו אפילו חלק עם מאמרים ישנים לתיאור תת-גרסה מוקדמת יותר של הנוזקה)

אתרים חשובים: לאחר חיפוש ראשוני רחב ומגוון לצורך בחירת נוזקה: **כנקודת התחלה מעמיקה: מאוד מומלץ להמשיך את החיפוש ולהעזר תוך חיפוש באתר:** <https://malpedia.caad.fkie.fraunhofer.de>

ובפרט ע"פ הרשימה שב: א **לחילופין לחפש ברשימת הנוזקות והכלים שב:** <https://attack.mitre.org/software/>

יתרון נוסף לאתרים אילו: האתרים כוללים גם רשימת מאמרים עדכניים. ומהתוכנות גם הפניה לקבוצות תקיפה שנעזרות בהם.

האתר של Mitre ATT&CK Framework בדגש אנטרפריז כולל גם מידע רחב יותר. <https://attack.mitre.org/>

כמובן ניתן לחפש נוזקות חדישות בפרסומי גופים וחברות אבטחת מידע.

כמובן היכרות רחבה עם אתרים ועם פרסומי מידע של חברות אבטחת מידע וחברות אנטי וירוס, הינה חלק מהלימוד.

הסבר: באתר MalPedia יש רשימה ובה פירוט מידע עדכני ורחב לכל נוזקה שברשימה:

בפרט יש רשימת נוזקות עדכנית וארוכה ב : (ממנה ניתן לבחור שם נוזקה אחת עבור המטלה)

[Malware Families \(fraunhofer.de\)](https://malpedia.caad.fkie.fraunhofer.de/families)

<https://malpedia.caad.fkie.fraunhofer.de/families>

לדוגמה:

<https://malpedia.caad.fkie.fraunhofer.de/details/win.stuxnet>

לחילופין ניתן גם לחפש נוזקה ברשימה שב :

<https://attack.mitre.org/software/>

הערה: לעיתים נוזקות זהות מקוטלגות בשמות שונים בחברות אבטחה ואתרים לעי"ל.

ורצוי מאוד לראות אם יש התייחסויות לנוזקה שבחרתם גם ב : <https://www.virusbulletin.com>

כדאי גם לחפש את השמות השונים של הנוזקה כי יתכן שרשימות שונות או גופים שונים מתייחסים לאותה נוזקה אבל בשמות שונים (וגם שמות שונים לאותה קבוצת תקיפה) .

אפשר לחפש גם בתתי הטכניקות שב Mitre ATT&CK FrameWork כדי למצוא שמות נוזקות וקבוצות תקיפה אבל גם מידע טכני . (שם מפורט איזה מהנוזקות עושות שימוש בטכניקות או בפרוצדורות ספיציפיות)

הערה: TTP הם ראשי תיבות של (TTPs (adversary tactics, techniques, and procedures

רצוי לחפש ולצרף גם מאמרים אקדמיים שקשורים לנוזקה או למנגנוניה או שיטות פעולתה (אם ישנם, לחפש באתר המכון במאגרי המידע שבספרייה. לשים לב שלכל מאגר-מידע מנוע חיפוש משלו). (יותר נדיר בתחום הנוזקות, אבל עדיין לעיתים יש מאמרים טובים במאגרי מידע אקדמיים)

רצוי לצרף רשימת מעקב אחרי פרסומים וציורים ב בטוויטר (אפשר גם מרשת בשם mastodon) של חוקרים מובילים. (שמות + URL) (אופציונאלי : ראו גם בנוסף בנוגע ל mastodon :

<https://www.theverge.com/2019/7/12/20691957/mastodon-decentralized-social-network-gab-migration-fediverse-app-blocking>

וראו (<https://joinmastodon.org>)

רצוי גם לבדוק גם קיום מאמרים בחברות אנטי-וירוס וחברות אבטחה מובילות וחברות מודיעין.

רצוי גם לצרף **צילום** של ציורים רלוונטים (כי הם עשויים להעלם או להיות בחשבון מושעה או מחוק)

לכל מאמר (או בלוג) עיקרי העוסק בתיאור ואו בניתוח: (ל 1 עד 3 מאמרים עיקריים בהם השתמשתם כבסיס עיקרי)

רצוי לפרט גם ביחס לתאריך הכתיבה של המאמר : כמה זמן עבר מאז "היציאה לשוק" ואו תחילת המתקפה העיקרית שנעזרה בו (בשעות ימים ואו חודשים ושנים) (גם ביחס לניתוחים ומאמרים כמה זמן עבר עד שפורסם ממועד המתקפה או מהשימוש הראשון בנוזקה) .

חשוב : לא לשכוח לחפש מאמרים עדכניים גם מהתקופה האחרונה (גם ביחס לנוזקות ותיקות !)

אפשר גם לראות חלוקה לסוגי נוזקות ומוסכמות שמות לנוזקות , מוסכמות בהן מיקרוסופט משתמשת ב:

<https://docs.microsoft.com/en-us/microsoft-365/security/intelligence/malware-naming?view=o365-worldwide>

אנחנו חוזרים ומדגישים: אתרים שמומלץ מאוד להעזר בהם כנקודת התחלה עבור רשימת מאמרים עדכניים שיש לבחור מתוכם (לאחר חיפוש כללי ומציאת נושא) :
רשימות נוזקות ומאמרים נוספים ביחס לנוזקות ב:

<https://malpedia.caad.fkie.fraunhofer.de/families> רשימת נוזקות

<https://malpedia.caad.fkie.fraunhofer.de/actors> רשימת קבוצות תקיפה

<https://malpedia.caad.fkie.fraunhofer.de/library> (טכניקות כלליות)

<https://attack.mitre.org/software/>

מומלץ לוודא שימוש במאמרים עדכניים (ורצוי לצרף הדפסה של רשימת מאמרים עדכניים גם אם לא תתייחסו לכולם, בשל ההיקף המצומצם של העבודה)

(אופציונאלי): הסמסטר אין צורך להשתמש ב ApiVector

[/https://malpedia.caad.fkie.fraunhofer.de/apiqr](https://malpedia.caad.fkie.fraunhofer.de/apiqr)

אתרים נוספים שמומלץ מאוד להעזר בהם כנקודת התחלה עבור רשימת מאמרים:

גיופי אבטחת סייבר מדינתיים ואו סקטוריים

אתרי חברות אבטחה ובפרט חברות אנטי וירוס ודוחות סיכום ודוחות מגמות שלהן.

לדוגמה:

<https://www.cisecurity.org/insights/blog/top-10-malware-q4-2023>

<https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-216a>

<https://www.bitdefender.com/files/News/CaseStudies/study/366/Bitdefender-Mid-Year-Threat-Landscape-Report-2020.pdf>

לדוגמה: /https://www.eset.com/int/business/resource-center/reports

(מותר גם להתמקד בגרסאות מוקדמות של נוזקות : אבל בבקשה לציין זאת בבחירה !)
ביחס למידע על מנגנונים טכניים :

האתרים של MITRE : בנוגע למידע על חולשות CVEs והאתר של ATT&CK וטכניקות תקיפה ובהם פירוט נוזקות וקבוצות תקיפה שעושות בו שימוש.

ביחס למידע על חולשות :

אתר ה CVE.mitre.org והאתר של NVD : בנוגע למידע על חולשות (<https://nvd.nist.gov>)

בנוסף כדאי לוודא שאולי יש התייחסות לנוזקות (אולי בשמות שונים) גם מול האתרים של:

<https://www.virusbulletin.com>

ובאתרים של חברות אנטי וירוס:

מקאפי <https://www.mcafee.com/enterprise/en-in/threat-center/mcafee-labs/reports.html>

מיקרוסופט :

<https://www.microsoft.com/en-us/wdsi/threats>

<https://securelist.com> (בפרט אתר המחקר :)

בנוסף לאתרים הנ"ל : דוגמאות אלטרנטיביות שניות לנקודות התחלה שונות לחיפוש :

דוגמאות: למילות חיפוש בגוגל : Top 10 Malware February 2022

list of malware Wikipedia

דוגמאות לרשימות אתרים שיכולות לשמש כנקודת מוצא ל חיפוש שמות נזקות ואו לאתרי חברות להן בלוגים ואתרים שמנתחים נזקות.
עם פרוט טכני מעמיק:

<https://www.cisecurity.org/blog/top-10-malware-february-2020>

<https://en.wikipedia.org/wiki/Category:Malware>

/ <http://www.malwaretruth.com/the-list-of-malware-types>

/ <https://heimdalsecurity.com/blog/top-financial-malware>

[Top 10 Malware February 2022 \(cisecurity.org\)](#)

<https://www.cisecurity.org/insights/blog/top-10-malware-february-2021>

<https://www.checkpoint.com/press/2022/february-2022s-most-wanted-malware-emotet-remains-number-one-while-trickbot-slips-even-further-down-the-index>

אפשר גם לחפש malware 10 top 2024

[/https://www.av-comparatives.org/list-of-consumer-av-vendors-pc](https://www.av-comparatives.org/list-of-consumer-av-vendors-pc)

לדוגמה נחפש : checkpoint trends pdf או checkpoint trends 2020

ונגיע ל :

https://www.checkpoint.com/downloads/product-related/infographic/H2_2017_Global_Cyber_Attack_Trends_Report.pdf

נחפש : Checkpoint trends malware 2020 או Checkpoint trends malware 2024

ונגיע ל

(דורש רישום קצר להורדה) <https://pages.checkpoint.com/2024-cyber-security-report>

[February 2022's Most Wanted Malware: Emotet Remains Number One While Trickbot Slips Even Further Down the Index - Check Point Software](#)

<https://blog.checkpoint.com/2022/03/09/february-2022s-most-wanted-malware-emotet-remains-number-one-while-trickbot-slips-even-further-down-the-index>

מומלץ להעזר בדוחות מחקר כלליים בנוגע לאיומים ונוזקות בניתוח שנתי ואז ענפי מעודכן .

לדוגמה: Global Treat Index של חברת צקפוינט :

<https://blog.checkpoint.com/2022/03/09/february-2022s-most-wanted-malware-emetet-remains-number-one-while-trickbot-slips-even-further-down-the-index>

לדוגמה:

[/https://securelist.com/apt-trends-report-q3-2019/94530](https://securelist.com/apt-trends-report-q3-2019/94530)

דוח לדוגמה למובייל ולסמרטפונים (למרות שלא בנושא עבודה זו) :

<https://www.trendmicro.com/vinfo/nl/security/research-and-analysis/threat-reports/roundup/review-refocus-and-recalibrate-the-2019-mobile-threat-landscape>

מומלץ להעזר גם בדוחות של חברות שעוסקות במחקר-אבטחה ומודיעין איומים .

מומלץ לראות מאמרים בהמשך העבודה (גם אם מוגדרים אופציונאליים) לקבלת מידע מעמיק נוסף (כולל שמות נוזקות) .

מומלץ גם לבצע חיפוש של מאמרים מדעיים דרך אתר הספרייה של המכון.

Tip : Library Search , After login to HIT Student's Portal.

מומלץ גם לחפש מאמרים באתרים של כנסים מקצועיים מובילים דוגמת BlackHat

דוגמאות לחיפוש :

Search Steps Samples:

Search google: " most common rat "

Found: <https://www.darkreading.com/perimeter/the-7-most-common-rats-in-use-today-/a/d-id/1321965>

Search google: top 10 malware February 2020

Found: https://resources.malwarebytes.com/files/2020/02/2020_State-of-Malware-Report.pdf see page number 13

Found: <https://www.cisecurity.org/blog/top-10-malware-february-2020/>

See list of 10 malware names .

From this list :

Find malware named Creber

Search Google : cerber malware analysis

Find Article named :

[/https://temasoft.com/information/cerber-ransomware-analysis](https://temasoft.com/information/cerber-ransomware-analysis)

You can also search for : " March 2020's Most Wanted Malware "

Or search for : “ Checkpoint Most Wanted Malware “

Found:

<https://www.checkpoint.com/press/2020/april-2020s-most-wanted-malware-agent-tesla-remote-access-trojan-spreading-widely-in-covid-19-related-spam-campaigns/>

<https://www.checkpoint.com/press/2020/march-2020s-most-wanted-malware-dridex-banking-trojan-ranks-on-top-malware-list-for-first-time/>

Or look for malwares in : <https://en.wikipedia.org/wiki/Category:Malware>

And look in google for : “malware-name malware analysis “

e.g: “ Zeus malware analysis “

e.g: “ Dridex malware analysis”

(2) (אופציונאלי) התייחסות היסטורית ורקע כללי.

פרק 2 במטלה הראשונה: כולו הוא אופציונאלי

אפשר לפרט רקע כללי ביחס לנוזקה או לכלי ליצירת נוזקות :

מי השתמש בו ? כנגד מי ? איזה קבוצות פשע או תקיפה ?
באיזה ארצות ואז ערים ואז סקטורים עיסקיים/תעשייתיים ?
רקע היסטורי .

(מופיע בהרחבה בסעיף 6) רקע קצר על הקבוצות תקיפה או הגוף שפיתחה אותה (או על זו שמייחסים לה את הפיתוח ובנפרד את השימוש)

מתי החל השימוש בנוזקה ? מתי היה בו שימוש בולט ? תוך כמה זמן התגלתה המתקפה ובנפרד תוך כמה זמן נחקרה הנוזקה ?

ביחס לנוזקה : מועדי הופעה ראשונים.

ביחס לנוזקה: מתקפות בולטות שעשו בו שימוש.

האם יש לנוזקה בסיס או שלד או רעיונות ממתקפות ואז נוזקות אחרות ?

https://en.wikipedia.org/wiki/Duqu_2.0 vs <https://en.wikipedia.org/wiki/Duqu>

האם היו צעדים מקדימים ? מאיזה סוג ?

האם יש בנוזקה שימוש ב פאקרים (Software Protectors) ? ואיזה ?
דוגמאות למאמרים :

<https://resources.infosecinstitute.com/category/certifications-training/malware-analysis-reverse-engineering/reverse-engineering-packed-/malware/top-popular-packers-used-in-malware>

<https://blog.malwarebytes.com/cybercrime/malware/2017/03/explained-packer-crypter-and-protector>

האם יש בנוזקה שימוש במנגנוני הפצה ואיזה ?
האם יש ממשק לבקרת ההפצה ?

עבור נוזקות ב SmartPhones או ב SmartTV :

האם הנוזקה כוללת מנגנון להעלאת הדרוג ("כוכבים") של המיקום שלה או של נוזקות אחרות ב Store PLAY/APP ?

האם בוצע תהליך של Search Engine Optimization SEO (קידום אפליקציות במנועי חיפוש של החנויות או פרסום זדוני אחר) לקידום המיקום של הנוזקות בחנויות האפליקציות ?

מאיזה אתרי הורדות ואז חנויות אפליקציות ניתן היה להוריד אותה ? (חנויות רישמיות, חנויות עצמאיות, חנויות פיראטיות, חנויות שכן העבירו בדיקות אבטחה ולמרות זאת החדירו נוזקות דרכן וכו)

(3) פרוט טכנולוגי כללי: (החלק העיקרי)

(הקלה לסמסטר זה, בקצרה) להוסיף תיאור של מרכיבי הקיטים העיקריים תפקידם ומנגנוניהם. (במידה ויש מספר תתי מודולים)

כדאי לפרט ארכיטקטורה, מנגנונים טכניים בולטים, API בשימוש.

(אופציונאלי) במידה ויש מימשק ניהול ונחקר: להרחיב על מימשק הניהול והמעקב החיצוני מכיון שרתי הפיקוד (חיצוני לנוזקה אבל הנוזקה מתקשרת איתו וגם את הפרוטוקול ניתן לנתח)

לפרט על מודולים עיקריים ואו תתי מרכיבים.

נשאל ונברר האם השתמשו בנוזקה זו במודלים או קטעי קוד שהופיעו קודם בנוזקות אחרות או במשפחות אחרות של נוזקות? (או שהדמיון מתגלה רק בעתיד).

לידיעה בלבד: הסבר והרחבה לנקודה זו: ראה הערה

"An interesting part of the story is that the code used by the CIA to hack into these devices was borrowed from ordinary malware."

ב

[/https://blog.checkpoint.com/2017/03/10/three-key-takeaways-from-vault-7-leak](https://blog.checkpoint.com/2017/03/10/three-key-takeaways-from-vault-7-leak)

רצוי לפרט רקע קצר על מודולים וקטעי קוד שנלקחו מנוזקות אחרות או קיטים אחרים.

האם נעשה שימוש במודולים של תוכנות מסחריות קיימות?
לדוגמה:

<https://unit42.paloaltonetworks.com/rootnik-android-trojan-abuses-commercial-rooting-tool-and-steals-private-information>

האם הנוזקה כוללת אינטרפרטר מובנה או שפת סקריפטים פנימית (דוגמת VBA ב Office או שפת IDC או פיתון לכתיבת מודולים ב IDA PRO או שפת LUA ב WireShark או LUA ב NMAP או דוגמת LUA ב FLAME ([https://en.wikipedia.org/wiki/Flame_\(malware\)](https://en.wikipedia.org/wiki/Flame_(malware))))

בניתוח מעמיק של נוזקה ניתן/רצוי לשים דגש טכני יותר ומעמיק, על מבנה הנוזקה ומנגנוניה ופחות על פירוט מתקפה בודדת.

הרחבה בנוגע ל: "לפרוט ארכיטקטורה, מנגנונים טכניים בולטים, API בשימוש.": כבסיס לתיאור להתחיל או לנסות להסתמך על סידרת הפעולות אותן מבצעת הנוזקה

לדוגמה: לראות את סדרת התיאור שב:

[/https://n1ght-w0lf.github.io/malware%20analysis/qbot-banking-trojan](https://n1ght-w0lf.github.io/malware%20analysis/qbot-banking-trojan)

כדאי להרחיב בנוגע לנוזקה שנבחרה על "attacks infection chain of recent" באם יש על כך מידע (למשל מספרי חולשות ומערכי הפצה שישמשו לצורך הדבקה המונית)

רקע טכנולוגי כללי בנוגע לנוזקה:

באיזה טכנולוגיות ושפות תכנות (באם ידוע) השתמשו בנוזקה לפיתוח הנוזקה?

באיזה טכנולוגיות (או מערכות הפעלה) השתמשו כיעד? יעד לתקיפה, יעד לחדירה (לא תמיד זהים)

(כלומר מה היו הטכנולוגיות ומערכות ההפעלה במוצרי התוכנה אותם הנוזקה תוקפת וחודרת)

תשובות לדוגמה: הנוזקה תוקפת שרתי וינדוס בגרסת R 2 2012 . תשובה למשל: הנוזקה תוקפת מכשירי IOT שמריצים לינוקס בגרסה 2.6 על מעבדי MIPS.

האם יש שימוש בולט ב API ספיציפיים ? בבדיקות ANTI DEBUG לסוגיה ? בטכנולוגיות ספיציפיות ? ואז מערכות ואז פרטוקולים ייעודיים ?

לדוגמה:

<https://www.blueliv.com/cyber-security-and-cyber-threat-intelligence-blog-blueliv/research/cryptoapi-in-malware/>

"We frequently find malware families that perform cryptography tasks by using the Microsoft Windows Cryptography API (CryptoAPI)."

תת נושא חשוב : האם יש שימוש במנגנוני הצפנה וקריפטולוגיה? (עשוי גם להיות פרק עצמאי) (להצפנת מידע של הקורבן, להצפנת פרטוקולים לתקשורת אל שרתי הפיקוד, זיוף סרטיפיקטים, גניבת סרטיפיקטים)

מה היו וקטורי החדירה ? האם נוצלו חולשות ? רצוי מספרי CVE

להסבר: <https://www.cvedetails.com/cve-help.php>

דוגמאות ל מספרי CVE :

https://www.us-cert.gov/sites/default/files/FactSheets/NCCIC/ICS_FactSheet_WannaCry_Ransomware_S508C.pdf

דוגמאות ל מספרי CVE :

The CVEs for the vulnerabilities associated with WannaCry exploits are as follows: CVE-2017-0143; CVE-2017-0144; CVE-2017-0145; CVE-2017-0146; CVE-2017-0147; and CVE-2017-0148

(אופציונאלי) האם פורסמו הודעות יצרן Vendor Announcements about vulnerability ?

האם יש שימוש בחולשות ידועות?

מהי כמות החולשות הלא ידועות והידועות בהן משתמשת או נעזרת הנוזקה?

(בנוגע לחולשות ולוקטורי החדירה : תשובה אפשרית לדוגמה: " לא יודע" - לא רצוי להשתמש בתשובה זו כי תהליך ניתוח בסיסי אמור לגלות לענות מהן החולשות בהן משתמשת הנוזקה. טיפ: חפשו מאמרים נוספים מפורטים יותר)

(תשובות אפשריות לדוגמה: לא נעזרה בחולשות כי הנוזקה מותקנת עי Dropper אחר ללא LPE או לאחר LPE (עי נוזקה אחרת) והיא לא נעזרת באף חולשה ידועה בעצמה, אולי מותקנת עי נוזקה אחרת, אשר בנוגע אליה אין לנו פרטים, כאשר הנוזקה הנחקרת אולי מותקנת מראש בהרשאות גבוהות יותר או שהנוזקה הותקנה במתקפת זיהום שרשרת אספקה)

מידע להרחבה בנוגע ל dropper :

[https://en.wikipedia.org/wiki/Dropper_\(malware\)](https://en.wikipedia.org/wiki/Dropper_(malware))

<https://www.techtarget.com/whatis/definition/dropper>

תוכנת הורדה dropper מכונה גם malware loader או downloader.

המשך שאלות לסעיף 3 – פרוט טכנולוגי :

מהן החולשות הבסיסיות שהשתמשו בהן ?

האם נעזרו בחולשות או ב ZERO DAYS או ב DAY 1 ? ובכמה חולשות נעזרו ? ניתן לפרט גם לגרסאות ודורות שונים של הנוזקה (באם ידוע)

לדוגמה: Stuxnet : 4 zero days

לדוגמה: NotPetya in June 2017 , using MS17-10 fixed at March 2017
לדוגמה:

<https://www.zdnet.com/article/stuxnet-attackers-used-4-windows-zero-day-exploits/>

כמה שנים קיימת החולשה הבסיסית ? מהו ה TimeLine של השימוש בה ומהו TimeLine של הפרסום שלה ? למי מיוחס השימוש או הגילוי הראשוני שלה ?

(אופציונאלי) כמה שנים קיימת הנוזקה כמשפחה ?

(אופציונאלי) תת פרק נפרד : הרחבה על החולשה הבסיסית והרקע שלה. או (ובהרחבה על החולשות העיקריות)

האם בוצע ניצול חולשות לצורך Privilege escalation ?

האם נעזרו בוקטורי חדירה **שאינם חולשות** (למשל דרך מתקפות על שרשרת האספקה) ? למשל שילוב הנוזקה כחלק מהתקנת תוכנות אחרות אותן אישר הקורבן או קיבל מותקנות מראש?

(אופציונאלי) בתוך הנוזקה Any Private keys or hard coded Passwords ? (הן עבור הפרוטקולים שלה והן לתקיפת מערכות במסגרת Later Movement)

לדוגמה ב [gamarue](https://www.microsoft.com/security/blog/2017/12/04/microsoft-teams-up-with-law-enforcement-and-other-partners-to-disrupt-gamarue-andromeda) יש שימוש עבור התקשורת ל C&C בהצפנת rc 4 עם מפתח HardCoded
<https://www.microsoft.com/security/blog/2017/12/04/microsoft-teams-up-with-law-enforcement-and-other-partners-to-disrupt-gamarue-andromeda>

(אופציונאלי) האם יש בנוזקה מנגנוני בדיקת סיסמאות ע"פ מילון או ע"פ Brute Force ?

האם יש מנגנוני הפצה עצמית ואו תקיפה של תולעת והדבקה רשתית ?

האם יש מנגנוני הפצה ואו תקיפה דרך הדבקה של אמצעים ניידים (DOK טלפונים סלולאריים במצב טעינה ועוד) ?

(אופציונאלי) האם לנוזקה יש יכולות תקיפה של MultiVector ?

לדוגמה ב Flame יש מודול Bluetooth שידוע לשאוב מידע מהתקני Bluetooth כלומר מ SmartPhones .

(4) פרוט טכנולוגי פרטני: (מנגנוניים טכניים פנימיים של הנוזקה)

(אופציונאלי) האם יש שימוש ב hooks /api hooking ?

<https://en.wikipedia.org/wiki/Hooking>

<https://www.apriorit.com/dev-blog/160-apihooks>
<https://www.apriorit.com/dev-blog/160-apihooks>

<https://www.apriorit.com/dev-blog/160-apihooks>

[/https://attack.mitre.org/techniques/T1179](https://attack.mitre.org/techniques/T1179)
<http://www.rohitab.com/apimonitor>
<https://www.microsoft.com/en-us/research/project/detours>
<https://github.com/microsoft/detours>
<https://github.com/microsoft/Detours/wiki>
<https://www.elastic.co/blog/hunting-memory>

לדוגמה עי hooking לשנות התנהגות של דפדפן או של המידע שהוא מקבל /שולח :

<https://www.sentinelone.com/labs/how-trickbot-malware-hooking-engine-targets-windows-10-browsers>

<https://www.cynet.com/attack-techniques-hands-on/api-hooking>

האם יש בנוזקה שימוש ב הזרקות קוד Binary code injection ? (לפרט בקצרה)
(אופציונאלי) אם כן מאיזה סוג של הזרקות קוד Binary ?
(אופציונאלי) האם הזרקות הקוד משמשות גם ל api hooking או רק להסתרה ?
(אופציונאלי) בנוגע להזרקות קוד Binary :יותר מידע:
https://en.wikipedia.org/wiki/Code_injection

<https://www.elastic.co/blog/ten-process-injection-techniques-technical-survey-common-and-trending-process>

<https://www.microsoft.com/en-us/wdsi/threats/malware-encyclopedia-description?name=Virus%3AWin32%2FParite.B>

[3 Effective DLL Injection Techniques for Setting API Hooks \(apriorit.com\)](https://www.apriorit.com/dev-blog/679-windows-dll-injection-for-api-hooks)

<https://www.apriorit.com/dev-blog/679-windows-dll-injection-for-api-hooks>

[Process Injection: Process Hollowing, Sub-technique T1055.012 - Enterprise | MITRE ATT&CK®](https://attack.mitre.org/techniques/T1055/012/)

<https://attack.mitre.org/techniques/T1055/012/>

see **Inject the DLL** into the explorer.exe process and modify the registry to point to that DLL:

<https://www.microsoft.com/en-us/research/publication/countering-persistent-kernel-rootkits-through-systematic-hook-discovery/>
<https://www.deepinstinct.com/2019/09/15/malware-evasion-techniques-part-1-process-injection-and-manipulation>

בנוגע ל : Reflective DLL Injection

<https://github.com/stephenfewer/ReflectiveDLLInjection>

<https://www.ired.team/offensive-security/code-injection-process-injection/reflective-dll-injection>

Reflective DLL injection is a technique that allows an attacker to inject a DLL's into a victim)
(process **from memory** rather than disk

שיטות מתקדמות להזרקת קוד *phantom DLL hollowing* ו *DLL hollowing*

<https://www.forrest-orr.net/post/malicious-memory-artifacts-part-i-dll-hollowing>

<https://www.cyberark.com/resources/threat-research-blog/masking-malicious-memory-artifacts-part-iii-bypassing-defensive-scanners>

הערה: הזרקת קוד בינארי שונה מהזרקת JavaScript או הזרקת SQL .

בנוגע להזרקות JavaScript :

<https://www.feroot.com/education-center/what-is-a-javascript-injection-attack>

<https://blog.sucuri.net/2022/05/massive-wordpress-javascript-injection-campaign-redirects-to-ads.html>

האם התגלו פרטים טכניים:

חשוב (!) : האם התגלו **KILL SWITCH** ?

דוגמאות למאמרים :

https://en.wikipedia.org/wiki/Kill_switch

<https://www.wired.com/2017/05/accidental-kill-switch-slowed-fridays-/massive-ransomware-attack>

<https://www.nst.com.my/lifestyle/bots/2017/05/238764/researcher-finds-kill-switch-cyberattack-ransomware>

<https://www.slashgear.com/microsoft-remote-software-kill-switch-confirmed-1656965>

<https://money.cnn.com/2017/01/12/technology/robot-law-killer-switch-taxes>

https://www.webopedia.com/TERM/K/kill_switch.html

<https://www.businesswire.com/news/home/20180307005884/en/Corero-Network-Security-Discovers-Memcached-DDoS-Attack>

<https://securityboulevard.com/2018/08/cyber-kill-switch-the-good-the-bad-and-the-potentially-ugly>

חשוב (!) : האם התגלה מנגנון למניעת התקפה / הדבקה שניה ? האם בוצעו תיקונים עצמיים (התקנה של עידכונים למערכת ההפעלה ותוכנות והגדרות של המחשב הפגיע על ידי

הנוזקה , כדי למנוע הדבקה שניה (בתהליך ? האם יש שימוש באובייקטי מערכת (למשל Mutex)
(כדי לסמן להעתקים אחרים של הנוזקה לא לפעול ו להימנע מהדבקה שניה.
לשיב לב שמנגנון למניעת הדבקה שניה , עשוי גם לשמש כסימני Indicator of Compromise
כלומר כסימן מזהה להדבקה .

להעמקה:

<https://cybersecurity.att.com/blogs/labs-research/malware-exploring-mutex-objects>

"Mutexes are usually used by malware creators to avoid the infection of a system by different instances of the same malware."

<https://www.sans.org/blog/looking-at-mutex-objects-for-malware-discovery-indicators-of-compromise>

https://en.wikipedia.org/wiki/Indicator_of_compromise

<https://www.fortinet.com/resources/cyberglossary/indicators-of-compromise>

https://net.cs.uni-bonn.de/fileadmin/user_upload/wichmann/Infection_Markers_as_Vaccine_against_Malware.pdf

האם הנוזקה מנצלת BackDoors קיימים?

(אופציונאלי) האם הנוזקה פותחת BackDoor או משנה הגדרות מחשב כדי להקל על חדירות אחרות ?

(דוגמה לפתיחת BackDoors : הוספת משתמשים נסתרים עם זכויות ADMIN , שינוי חוקים ב FireWall , הוספת חוקי Exclude לתוכנות אנטי וירוס או ביצוע Disable לתוכנות אנטי וירוס , פתיחת Shares , התקנת Device Drivers עם פגיעויות לניצול עתידי)

(אופציונאלי) האם התגלו Malware Updates ? and Payload Downloads ?

האם נעשה שימוש בקוד ואו רעיונות מקיטים אחרים ואו נזקות אחרות.

האם יש בקיט מרכיבים מודולריים? האם ניתנים לקניה בנפרד ? (בנוזקות " מיסחריות ")

האם יש בקיט מרכיבים מודולריים שנקנו בנפרד (לדוגמה מודלי RAT) ? ונמצאים בשימוש של נזקות אחרות ואו נוספות ?

האם הנוזקה מכילה שפת סקריפטים פנימית ואו מרכיבים מודולריים ?

דוגמאות למאמרים :

Extra info about internal scripts languages:

[https://en.wikipedia.org/wiki/Flame_\(malware\)](https://en.wikipedia.org/wiki/Flame_(malware))

Use of Lua:

[https://en.wikipedia.org/wiki/Lua_\(programming_language\)](https://en.wikipedia.org/wiki/Lua_(programming_language))

<https://docs.microsoft.com/en-us/office/vba/library-reference/concepts/getting-started-with-vba-in-office>

<https://nmap.org/book/nse-language.html>

(אופציונאלי) האם יש IOC (Indicators of compromise) ומתי פורסמו?

(אופציונאלי):

האם זהו IOCs ? ובכלל זה : כתובות IP באם יש, חתימות, שמות ספריות וקבצים, שמות מפתחות, שמות מתחמים Domains, זיהוי חתימות של קטעי קוד בינאריים ייחודיים, שמות מפתחות רגיסטרי, יצירת שמות אובייקטים ייחודיים בקרנל כגון Mutex פרטיים ועוד.

הערה: תפקיד חוקר הנוזקות גם להפיק IOC עבור פרסום ועבור מערכות גילוי אוטומאטי.

דוגמאות למאמרים :

https://en.wikipedia.org/wiki/Indicator_of_compromise

<https://www.sans.org/reading-room/whitepapers/forensics/ioc-indicators-compromise-malware-forensics-34200>

<https://cyware.com/educational-guides/cyber-threat-intelligence/what-is-open-indicators-of-compromise-openioc-framework-ed9d>

<https://web.archive.org/web/20170914034202/https://blogs.rsa.com/understanding-indicators-of-compromise-ioc-part-i/>

דוגמאות ל IOC :

In : <https://www.us-cert.gov/ncas/alerts/TA17-132A>

Alert (TA17-132A)

Indicators Associated With WannaCry Ransomware

See [TA17-132A_stix.xml](#) for IOCs developed after further analysis of the WannaCry malware.

(אופציונאלי) האם נעשה שימוש בטכניקות אנטי דיבוג ואיזה ?
דוגמאות למאמרים :

CPR Anti-Debug Encyclopedia: The Check Point Anti-Debug Techniques Repository

<https://research.checkpoint.com/2020/cpr-anti-debug-encyclopedia-the-check-point-anti-debug-techniques-repository>

<https://anti-debug.checkpoint.com>

<https://www.deepinstinct.com/2017/12/27/common-anti-debugging-techniques-in-the-malware-landscape>

<https://www.intertrust.com/blog/nine-anti-debugging-techniques-for-application-security>

<https://resources.infosecinstitute.com/category/certifications-training/malware-analysis-reverse-engineering/anti-disassembly-anti-debugging-anti-virtual-machine/#gref>

<https://blog.malwarebytes.com/threat-analysis/2013/07/zeroaccess-anti-debug-uses-debugger>

<https://blog.malwarebytes.com/threat-analysis/2014/09/five-anti-debugging-tricks-that-sometimes-fool-analysts>

<https://resources.infosecinstitute.com/topic/anti-disassembly-anti-debugging-and-anti-vm>

https://web.archive.org/web/20170826132353if_/https://www.symantec.com/avcenter/reference/Virtual_Machine_Threats.pdf

(אופציונאלי) יש לפרט אם ואיך נעשה שימוש בטכניקות הסתרה obfuscation)

בנוסף ל anti-debugging techniques (.

(אופציונאלי) יש לפרט אם ואיך נעשה שימוש בטכניקות anti-debug ? Anti-vm ?

(אופציונאלי) יש לפרט אם ואיך נעשה שימוש בטכניקות Evasions ? (להתחמקות ממערכות גילוי אוטומאטיות)

(אופציונאלי) יש לפרט אם ואיך נעשה שימוש בטכניקות anti-forensic ?

(אופציונאלי) טכניקות anti-forensic לדוגמה :

א. שימוש בשיטות של fileLess Malware (כי לעיתים לא נשאר קובץ בינארי על הדיסק ...)

ב. שימוש בפקודות מחיקה UNINSTALL והשמדה מרחוק (למשל ראו ב Flame פקודות התאבדות)

ג. שימוש במודולי Wiper להשמדת המחשב ואו מחיקתו המלאה בתום המתקפה כדי להקשות על מציאת ארטיפקטים או סימני חדירה.

<https://media.kaspersky.com/en/business-security/fileless-attacks-against-enterprise-networks.pdf>

• <https://www.paloaltonetworks.com/cyberpedia/what-are-fileless-malware-attacks>

(אופציונאלי) יש לפרט אם ואיך בניתוח הנוזקה נעשה שימוש בטכניקות memory forensics ?

תת נושא טכני fileless Malware (כולו אופציונאלי, אלא אם הנוזקה היא מסוג Fileless Malware)

(אופציונאלי) בנוזקה שבחרתם : האם נעשה שימוש בתוכנות (או פקודות) מערכת קיימות ואו שימוש במנגנונים שהם fileless ?

/ <https://encyclopedia.kaspersky.com/glossary/bodiless-malware>

<https://www.cybereason.com/blog/fileless-malware>

https://en.wikipedia.org/wiki/Fileless_malware

<https://www.mcafee.com/enterprise/en-us/security-awareness/ransomware/what-is-fileless-malware.html>

<https://media.kaspersky.com/en/business-security/fileless-attacks-against-enterprise-networks.pdf>

- <https://www.paloaltonetworks.com/cyberpedia/what-are-fileless-malware-attacks>
<https://zeltser.com/fileless-malware-beyond-buzzword/>
- https://www.trendmicro.com/en_us/research/20/e/netwalker-fileless-ransomware-injected-via-reflective-loading.html
- <https://encyclopedia.kaspersky.com/glossary/bodiless-malware/>

(הכוונה להעזרות בפקודות דוגמת CMD PowerShell netsh wmic ו WMI וגם AutoIT)

הערה: לעיתים יש גם נוזקות בינאריות שהן Fileless ומבצעות הזרקות קוד בינארי לאחר הפעלת ShellCode, ללא העזרות ב DLL וללא כתיבה כולשהיא לדיסק (כדי לא להתגלות עי תוכנות אנטי וירוס).

אבל בגישה עכשווית פופולארי לייחד את השם FileLess Malware ולקרוא בשם זה רק לקטיגוריות הנוזקות מבוססות פקודות מערכות ושפות סקריפטים, שלעיתים גם הן יושבות רק בזיכרון RAM (למשל מועברות ונכתבות כקלט ישירות לאינטרפרטרים דוגמת WMIC או CMD או PowerShell) אבל לזכור שניתוח נוזקות בינאריות שיושבות רק ב RAM דורש לרוב לשמור ולנתח DUMPS של הזיכרון RAM של כל מערכת ההפעלה או של תהליכים מושפעים. ולא רק לחפש מימצאים/ארטיקפטים ב HardDisk.

<https://docs.microsoft.com/en-us/windows-server/networking/technologies/netsh/netsh-contexts>

<https://docs.microsoft.com/en-us/windows-server/networking/technologies/netsh/netsh-wins>

(אופציונאלי) לצורך לימוד והעמקה ניתן לקרוא יותר בנושא obfuscation ב :

<https://blog.malwarebytes.com/threat-analysis/2013/03/obfuscation-malwares-best-friend>

https://www.profsandhu.com/cs5323_s18/yk_2010.pdf

[/LESS Good:](#)

<https://securityboulevard.com/2020/02/what-is-malware-obfuscation>

<https://resources.infosecinstitute.com/category/certifications-training/malware-analysis/reverse-engineering/malware-obfuscation-encoding-encryption/malware-obfuscation>

האם הנוזקה הופצה עם "פאקר" או "קוד-פרוטקטור"? האם פאקר פרטי או "מסחרי" "פופולארי"?

האם הנוזקה הופצה עי רשתות BOTNET גדולות או רשתות ידועות?

אופציונאלי: האם יש ניתוח על פי MITRE ATT&CK® framework (ראו פרק 10 ייעודי)

רק לפרט האם במחקר הוצג ניתוח מיפוי צעדים ופעילות ע"פ שלבי ה MITRE ATT&CK Framework (והקלה: אין צורך לפרט את המיפוי) ?

5) פרוט טכנולוגי פרטני: מערכי הפצה ושרתי פיקוד C2 C&C Command and Control Server & Protocols פרוטוקולי תקשורת וארכיטקטורת תקשורת אל ה C&C

בהיקף קטן:

הקלה: פרק 5 כולו הוא אופציונאלי בסמסטר זה.

פרוט טכני (רצוי פרטני) של : מערכי הפצה (כי לעיתים ההפצה היא עי פקודה לנוזקה אחרת או ל BOTNET שלם)

באם ידוע: מהו מבנה מערכי שליטה ופיקוד (כולל פרוט התוכנות בצד השרתי) .

האם הנוזקה מממשת רשתות Peer2Peer לצורך התגברות על הפרדת רשתות ועבור הורדת עידכונים ותקשורת אל מערכי השליטה והפיקוד ?

מהם שרתי הזלגה של מידע גנוב

האם יש ומהם מנגנוני עידכון והורדת מודולים נוספים.

האם יש מנגנוני עידכון לרשימות חליפיות של שרתי פיקוד והאם יש ומנגנונים להתגברות על חסימה של שרתי פיקוד

(מעבר לשרת פיקוד אלטרנטיבי, רשימות שרתים אלטרנטיבים קבועים מראש קבלת רשימות מעודכנות חדשות של שרתי פיקוד, DGA)

ארכיטקטורות תקשורת של מערכי C&C ושרתי העידכונים .

(אם ידועים) בסדרות תקיפה עיקריות.

האם לנוזקה יש וקטור חדירה עצמי או שמותקנת עי נוזקות אחרות ?

באם אין וקטור חדירה עצמי :

האם ידועים מהם מנגנוני ההפצה עבור הנוזקה ? (כי יתכן שהנוזקה מופצת במספר ערוצים שונים)

ניתוח אמצעי ופרוטוקולי התקשורת של שרתי הפיקוד והעידכון (כולל פיענוח הצפנות של פרוטוקולי התקשורת וניסיון הגעה ל Bot Master ששולט מרחוק בשרתי הפיקוד)

האם יש בנוזקה מנגנונים להתגברות על Air Gap ותקשורת בין, אל ומחוץ לרשתות בדרגות בידוד או הפרדה, וסגמנטציה שונות. (לדוגמה : ארכיטקטורת Peer2peer) (הערה : מוצרי FireWalls FW חומות אש מתקדמים מציעים יכולות : מיקרו סגמנטציה)

האם בוצעו פעולות איתור ו תקיפות ואו מבצעי TakeDown
כנגד תשתיות ואו קבוצות שפיתחו ואו השתמשו בנוזקה
(לפיתוח, פיקוד ואו להפצה ואו להחדרה לארגונים) .

האם בוצעו פעולות סייבר מרחוק כנגד השרתים ואו כנגד נכסים
השייכים לקבוצת התקיפה שהפיצה את הנוזקה ואו ביצעה את
המיתקפה.

האם יש שימוש ב Covert Communication channels דוגמת DNS Tunneling ?

5.1) האם לנוזקה יש מנגנון שליטה מבחוץ ? (או האם הנוזקה אוטונומית ?)

ראו הסברים על שרתי פיקוד:

[DCX \(trendmicro.com\)](https://www.trendmicro.com/dcX/)

https://success.trendmicro.com/dcX/s/solution/1121033-what-to-do-in-case-of-command-and-control-c-c-callback-detection?language=en_US

<https://www.trendmicro.com/vinfo/us/security/definition/command-and-control-server>

<https://www.paloaltonetworks.com/cyberpedia/command-and-control-explained>

<https://sites.cs.ucsb.edu/~kemmm/courses/cs595G/TM06.pdf>

אופציונאלי: האם לנוזקה יש מנגנונים אוטונומיים? או מבוססי AI ?

מנגנוני Lateral Movement אוטונומיים או ידניים מופעלים מרחוק ? multi-vector ?

האם יש בנוזקה מנגנון יזיהוי תוים ואותיות (OCR) ?מנגנוני שבירת Captcha ?

במסגרת מנגנונים אוטונומיים: האם לנוזקה יש מנגנוני סריקה והפצה עצמית ובפרט מנגנוני חיפוש נכסים וויעדים לתקיפה.

הפניה למאמרים לצורך העמקה: (רק למי שרוצה. לא חובה)

<https://www.crowdstrike.com/epp-101/lateral-movement>

<https://www.lastline.com/blog/lateral-movement-what-it-is-and-how-to-block-it>

<https://cymulate.com/lateral-movement>

<http://www.logixconsulting.com/2019/10/31/what-is-a-multi-vector-cyber-attack>

לראות כיון עתידי: DARPA Challenge Grand Cyber (מנגנונים אוטונומיים משולבי AI להגנה ולהתקפה. לעניות דעתי: זהו העתיד של הסייבר אבל גם של כלי נשק צבאיים)

https://en.wikipedia.org/wiki/2016_Cyber_Grand_Challenge

<https://www.youtube.com/watch?v=v5ghK6yUJv4>

5.2) האם יש מידע על שרת Command and Control ואו על הפרוטוקול שלו ואו ארכיטקטורה?

<https://www.secpod.com/blog/command-and-control-servers-things-you-should-know>

<https://arxiv.org/ftp/arxiv/papers/1408/1408.1136.pdf>

<https://securityaffairs.co/wordpress/88303/malware/miori-botnet-new-c2-protocol.html>

[/https://www.activecountermeasures.com/mitre-attck-matrix-custom-c2-protocol](https://www.activecountermeasures.com/mitre-attck-matrix-custom-c2-protocol)

Book: Botnets: Architectures, Countermeasures, and Challenges

https://books.google.co.il/books?id=uyCyDwAAQBAJ&pg=PT122&lpg=PT122&dq=c2+malware+protocols&source=bl&ots=Bksd2aLRNx&sig=ACfU3U0uA9WIWtBhtQPp8HeXoDh67SqqyRA&hl=iw&sa=X&ved=2ahUKEwiYqKmq_d3pAhWrk4sKHdM3B9oQ6AEwCnoECAgQAQ#v=onepage&q=c2+malware+protocols&f=false

לדוגמה מידע על איתור שרתי פיקוד של פגסוס שמיוחס ל NSO:

[https://tspace.library.utoronto.ca/bitstream/1807/95391/1/Report%23113--hide and seek.pdf](https://tspace.library.utoronto.ca/bitstream/1807/95391/1/Report%23113--hide+and+seek.pdf)

ולשים לב שלאחר איתור שרתי הפיקוד של NSO, בוצע גם איתור של סמארטפונים נגועים שפנו לאותם שרתי פיקוד עי איתור סימני פניה מוקדמת ב CACHE של שרתי DNS מקומיים, שעצם הימצאות מידע **מוקדם** על כתובות שרתי פיקוד של NSO, הוכיח שפנו מאותם איזורים אל שרתי הפיקוד.

5.3) אם יש מנגנוני תקשורת: מהו סוג מנגנוני התקשורת לפיקוד ?
האם יש שימוש בארכיטקטורת תקשורת ייחודית ומהי ?
(Network Architecture) (p2p), היררכי, מרכזי ועוד , Tunnels , תקשורת לווינית)

דוגמאות למאמרים :

<https://www.trendmicro.com/vinfo/us/security/definition/command-and-control-server>

<https://www.paloaltonetworks.com/cyberpedia/command-and-control-explained>

הסבר על ארכיטקטורות:

<https://sites.cs.ucsb.edu/~kemm/courses/cs595G/TM06.pdf>

[/https://www.malwarepatrol.net/command-control-servers-c2s-fundamentals](https://www.malwarepatrol.net/command-control-servers-c2s-fundamentals)
<https://www.anomali.com/blog/the-interplanetary-storm-new-malware-in-wild-using-interplanetary-file-systems-ipfs-p2p-network>

<https://www.us-cert.gov/ncas/alerts/TA14-150A>
<https://attack.mitre.org/tactics/TA0011>

(אופציונאלי) האם יש שימוש במנגנוני תקשורת מיוחדים ?

דוגמה למאמר:

[/https://securelist.com/satellite-turla-apt-command-and-control-in-the-sky/72081](https://securelist.com/satellite-turla-apt-command-and-control-in-the-sky/72081)
[/research.dyn.com/2013/11/mitm-internet-hijacking](https://research.dyn.com/2013/11/mitm-internet-hijacking)

5.4) האם נותחו פרוטוקולי ההזלגה ואו הפיקוד של הנוזקה C&C C2 Command and Protocols

במסעי תקיפה : האם אותרו שרתי פיקוד

האם יש פרוט על תשתיות הפיקוד (היקף , גודל , פיזור גיאוגרפי , משך קיום)

(אופציונאלי) האם יש מידע על שרתי הפיקוד של הנוזקה: C&C C2 Command and Control Servers

דוגמה לאיתור :

<https://citizenlab.ca/2018/09/hide-and-seek-tracking-nso-groups-pegasus-spyware-to-operations-in-45-countries>

(אופציונאלי) האם יש בנוזקה שימוש והאם נותחו DGA ?

הערה: DGA Domain generation algorithm (ראו:

(https://en.wikipedia.org/wiki/Domain_generation_algorithm)

<https://blog.malwarebytes.com/security-world/2016/12/explained-domain-generating-algorithm>

https://web.archive.org/web/20160403200600/https://www.damballa.com/downloads/r_pubs/WP_DGAs-in-the-Hands-of-Cyber-Criminals.pdf

עבור ערוצי הפיקוד: האם נעשה שימוש בהצפנה? מאיזה סוג הצפנה והאם אותרו מפתחות הצפנה ?

(אופציונאלי) האם בוצעו מבצעי וניטרול הורדה TakeDown כנגד תשתיות הפיקוד ועל ידי איזה גורמים , (לפרט ע"פ חלוקה גיאוגרפית וסקטוריאלית) (מי) .

האם בוצע זיהוי קבוצת התקיפה ע"פ זיהוי ואו שיוך שרתי הפיקוד לפעולות קודמות.

האם בוצע זיהוי קבוצת התקיפה ע"פ TTPs ו קישור לפעולות קודמות או נזקות שמקושרות לקבוצה.

האם בוצע זיהוי של הרשתות השונות ואו הנוזקות השונות או מסעי הפרסום שהפיצו במקור את הנוזקה (להבדיל משרתי הפיקוד הנוכחיים שמשמשים את הנוזקה כעת בשלבי פעולתה ?)

הערה: הבנת שרשרת ההדבקה שונה מהבנת שרשרת הפיקוד הנוכחית.

לעיתים רשתות הפצה משמשות להתקנת הנוזקה שלאחר מכן משתמשת ברשתות נפרדות לפיקוד.

לעיתים מחקר מוצלח של אלגוריתמים התקשורת לעידכונים ואו לפיקוד , מאפשר לזייף שרתי פיקוד שיתנו פקודה לכמות גדול של נזקות מותקנות למחוק את עצמן.

האם זוהי **פוענח פרטוקול התקשורת** ? (משרתי הפיקוד לכיון הנוזקה.)

האם זוהי **פוענח הצפנה פרטוקול התקשורת** ? (משרתי הפיקוד לכיון הנוזקה. ומהנוזקה אל שרתי הפיקוד והזלגת המידע)

כיצד הנוזקה שולחת מידע גנוב מוצפן ?

בהקשר לשאלה על מבצעי TakeDown ותשתיות פיקוד :

מאמרים בנוגע למבצעים לדוגמה:

[/https://blogs.microsoft.com/on-the-issues/2020/03/10/necurs-botnet-cyber-crime-disrupt](https://blogs.microsoft.com/on-the-issues/2020/03/10/necurs-botnet-cyber-crime-disrupt)

<https://www.interpol.int/ar/1/1/2016/Avalanche-network-dismantled-in-international-cyber-operation>

<https://www.interpol.int/News-and-Events/News/2015/INTERPOL-coordinates-global-operation-to-take-down-Simda-botnet>

<https://www.microsoft.com/security/blog/2017/12/04/microsoft-teams-up-with-law-enforcement-and-other-partners-to-disrupt-gamarue-andromeda>

<https://www.fbi.gov/news/testimony/taking-down-botnets>

<https://www.microsoft.com/security/blog/2017/12/04/microsoft-teams-up-with-law-enforcement-and-other-partners-to-disrupt-gamarue-andromeda>

<https://www.europol.europa.eu/newsroom/news/andromeda-botnet-dismantled-in-international-cyber-operation>

[/https://news.microsoft.com/videos/what-is-a-botnet](https://news.microsoft.com/videos/what-is-a-botnet)

6) (אופציונאלי) פרוט כללי וטכני ביחס לקבוצה מאחורי הנוזקה .

(פיתוח ושימוש) (להפריד בין מפתחי הנוזקה לבין המשתמשים בה, לעיתים אותו ארגון)

כללית רק באם אם ידוע: פרוט כללי וטכני ביחס לקבוצה מאחורי הנוזקה ושיטות וכלים דומים בהם היא משתמשת (TTPs) שמאפיינים אותה ואו מאפשרים את זיהוייה או את הקישור אליה).
בפרט: מהו שם הקבוצה (או שמות הקבוצה בחברות שונות) ואיזה חברות מחקר מתמקדות בה ואו מכירות אותה .

לעיתים מזהים ומאפיינים קבוצות תקיפה ע"פ שימוש חוזר בתשתיות כגון שרתי פיקוד ואו כלי תוכנה כגון נוזקות ושיטות טכניות בנוזקות ובאופן כללי ע"פ ה TTPs בהן הקבוצות תקיפה משתמשות.

ניתן לראות רשימה עדכנית של קבוצות תקיפה ומידע עליהן ב: malpedia :

[Threat Actors \(powered by MISP\) \(fraunhofer.de\)](https://malpedia.caad.fkie.fraunhofer.de/actors)

<https://malpedia.caad.fkie.fraunhofer.de/actors>

וגם ב mitre att&ck יש לנו רשימה של קבוצות תקיפה ב:

[/https://attack.mitre.org/groups](https://attack.mitre.org/groups)

בנוגע ל TTP : (Tactics, Techniques, and Procedures (TTPs))

https://csrc.nist.gov/glossary/term/Tactics_Techniques_and_Procedures

<https://www.cytomic.ai/trends/ttp-advantages-cyberintelligence>

[/https://zvelo.com/tag/ttp](https://zvelo.com/tag/ttp)

גישה של תיאור ה TTPs היא כוללת, ואפשר להתייחס בפשטות גם לגילוי שימוש חוזר במנגנונים טכניים ובתשתיות שרתים מתקיפות קודמות (דוגמת שרתים ששימשו בנוזקות קודמות או מסעי תקיפה קודמים).

בנוסף אפשר להתייחס בפשטות גם ליעדי תקיפה זהים.

האם במאמרים יש חשדות ואו זיהוי של הגורם מאחורי הפיתוח והשימוש בנוזקה ?

מהם השמות המיוחסים לאותו גורם ומהם שמות הנוזקות הנוספות המקושרות אליו.

האם יש דימיון למרכיבים טכניים נוספים שנעשה בהם שימוש בנוזקות אחרות עי אותו גורם ?

דוגמה למאמר זיהוי:

<https://unit42.paloaltonetworks.com/unit42-paranoid-plugx>

https://unit42.paloaltonetworks.com/pkplug_chinese_cyber_espionage_group_attacking_asia

The name comes from the tactic of delivering PlugX malware inside ZIP archive files as part of a DLL side-loading package. The ZIP file format contains the ASCII magic-bytes "PK" in its header, hence PKPLUG.

While tracking these attackers, Unit 42 discovered additional, mostly custom malware families being used by PKPLUG beyond that of just PlugX.

האם יש זיהוי כללי של שיטות פעולה דומות המאפיינות את אותו גורם :
(TTP – Tactics, Techniques, and Procedures)

מתי זוהתה/התחילה הפעילות של אותו גורם והאם לנוזקה יש גרסאות עיקריות שונות ?
(אופציונאלי) האם תשתיות הפיקוד קושרו לאותו גורם ?
האם הגורם פעיל רק באיזורים מסוים גיאוגרפית או רק בסקטורים מסויימים (דוגמת תעשיות נפט) ?
האם הגורם הנ"ל עדיין פעיל בשנה האחרונה ?
האם בוצעה האשמה או ייחוס כלפי גורם כולשהוא (Attribution) ומי השמיע את ההאשמה ?
(אופציונאלי הסמסטר) האם בוצעו מבצעי TakeDown או השתלטות ואו חסימות כנגד הגורם
התוקף ואו נגד התשתיות שלו ? ואם כן אז ו מתי ואיך וע"י מי. ?

7) (אופציונאלי) התייחסות לסוף הסרט: בדיעבד: (בפרפסקטיבת זמן)

לציין חדשות אחרונות ועדכניות בנוגע לנוזקה לקיט ואו לכלי תקיפה ואו קבוצת התקיפה.
האם הנוזקה עדיין פעילה ?
האם יצרנים פרסמו תיקונים עבור החולשות הרלוונטיות ?
האם פרסמו המלצות ל Mitigations , דרכי הימנעות ? (למשל: התקנת תיקונים או שינוי הגדרות מערכת)
האם נתפסו או זוהו או הודו ואו נעצרו היוצרים ואו המפעילים של הנוזקה ?
האם דלף לרשת קוד המקור של הנוזקה ?
מה היתה מטרת המתקפות שנעזרו בנוזקה ? ניתוח בדיעבד (התייחסות תמציתית קצרה)
האם יש וריאנטים (דורות, גרסאות והתפצלויות) חדשים לנוזקה ? (מאז המתקפה המקורית)
האם היא מבוססת על נזקות אחרות?
האם יש נזקות אחרות שמבוססות עליה?
האם הנוזקה בשימוש בימינו (כמות דיווחים בעולם בשנים האחרונות, בחלוקה ע"פ איזורים גיאוגרפיים)
במקרה של נזקת שלד (ליצירת נזקות אחרות) : האם יצרנים פרסמו כלי הסרה עבור הנוזקה ?
האם בוצע שימוש מאוחר יותר באותן תשתיות פיקוד של הנוזקה , במתקפות אחרות נוספות ?

8) התייחסות כלכלית (אופציונאלי , בצמצום) לתהליך פיתוח הנוזקה

זהו פרק אופציונאלי : (לא חובה לעשות ...כן מוזמנים לאמץ שאלות כצורת חשיבה בכל נושא פיתוח)
כמה גרסות "ישנות " ואו מוקדמות יש לכלי (דורות קודמים) ? וכמה הושקע בפיתוח בעבר ?
האם התפרסמו הערכות למחיר הערכה. (אין צורך להיכנס לרשת האפלה ולנסות לקנות ...)
(המחיר לקניה ברור שפחות רלוונטי לקוד שדלף... אבל כן ניתן לנסות להעריך את מידת ההשקעה בפיתוח הכלי או הערכה או הנוזקה.)
האם התפרסמה ואו האם יש לכם הערכה לכמות ההשקעה לצורך פיתוח הערכה או הקיט (מעבר לגילוי ואיסוף הפגיעויות) ? כנ"ל בנוגע למאמצי השייחוק והמודעין וההפצה בשטח לצורך הדבקה?

<https://en.wikipedia.org/wiki/Stuxnet>

Experts believe that Stuxnet required the largest and costliest development effort in malware history.

<https://www.vanityfair.com/news/2011/03/stuxnet-201104>

<https://resources.infosecinstitute.com/duqu-2-0-the-most-sophisticated-malware-ever-seen>

ניתן לנסות להעריך את מידת ההשקעה בפיתוח על פי "שנות אדם" או מיגוון תחומי מומחיות ואו כמות שפות שנדרשו לצורך פיתוח הקיט ואו הכלי. **וכמובן כמות החולשות בהן נעזר.**

ניתן להעריך את משך השנים (משך קלנדרי) של הפיתוח.

לחילופין ניתן לנסות לנסות להעריך את גודל הגוף העומד מאחורי הכלי ואת עוצמתו הפיננסית ואו הטכנולוגית. כנ"ל ביחס לפעילויות מקדימות (מסעי איסוף מודעין או פיתוח גרסאות קודמות)

9) בתמציתיות: פרוט טכני קצר על ה CVE ואו החולשות עליהם מתבססת הנוזקה או חולשות שנעזרה בהם

נושא זה נשאל גם בפרקים קודמים.

כאן יש לציין את מספרי ה CVE.

רצוי לפרט האם בעת השימוש הראשוני ע"י הנוזקה השימוש היה מסוג Zero Day או One Day .
יש לציין גם פרסומים של היצרן של התוכנה ביחס להודעה על החולשות (רצוי תוך ציון מספרי הזיהוי שנתן גם היצרן לפרסומיו) וגם על תיקונים.
יש לפרט בתמציתיות על החולשות.

יש לצרף לרשימת המאמרים גם מספר מאמרים ביחס לחולשות הרלוונטיות.

יש לצרף URL למאמרים והעתק המאמרים ואו צילום שלהם (אפשר צילום מסך נגלל) .

רצוי לאתר גם מאמרים של המגלים הראשוניים של החולשה.

רצוי לצרף גם פירוט מ ה NVD National Vulnerability Database של משרד התקנים האמריקאי ביחס לכל חולשה.

ראו: <https://nvd.nist.gov> ובפרט: <https://nvd.nist.gov/search>

יש לנסות למצוא האם פורסמו POCs (Proof of Concepts) או Exploits נפרדים עצמאיים עבור החולשות העיקריות בשימוש הנוזקה לפני ואחרי יציאת הנוזקה לשוק ואו לאחר התגלותה. לדוגמה:

<https://github.com/qazbnm456/awesome-cve-poc/blob/master/MS17-010.md>

כדאי שלים לב שנוזקות להן יש מספר גרסאות כולל גרסאות מוקדמות ומאוחרות: יתכן ועושות שימוש במגוון חולשות (כלומר עברו להשתמש בחולשות חדישות)

10) (אופציונאלי ולא נדרש הסמסטר!) ניתוח הנוזקה ואופן פעולתה ע"פ MITRE ATT&CK FRAMEWORK

וע"פ מודל ה Cyber Kill Chain של לוקהיד מרטין

אפשר להעמיק ב <https://attack.mitre.org> ובפרט לראות ATT&CK Matrix for Enterprise

אפשר לראות גם ב:

<https://www.cybereason.com/mitre-attck>

<https://www.cybereason.com/unleashing-the-true-potential-mitre-attck>

האם יש מאמרים שמנתחים את פעילות הנוזקה ע"פ פירוט הצעדים, הטקטיקות, הטכניקות והפרוצדורות כמתואר ב Mitre Att&ck Framework ?

והאם ב Mitre Att&ck Framework בתיאורי הפרוצדורות האם יש איזכור של הנוזקה ושיטותיה ? (כלומר האם שיטות הפעולה של הנוזקה הוכנסו ל Mitre Att&ck Framework) ?

כדאי להכיר (ולהשוות ל) גם את המודל של לוקהיד מרטין the_Cyber_Kill_Chain

האם שימוש בגישת ההגנה ע"פ המודל של לוקהיד מרטין היה עוצר את המתקפה (במקרה של שימוש בנוזקה כחלק ממתקפה ואו כ APT לצורך תקיפה ממוקדת כנגד ארגון) .

בנוגע ל : מודל ה Cyber Kill Chain של לוקהיד מרטין

<https://www.varonis.com/blog/cyber-kill-chain>

<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

[https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/Seven Ways to Apply the Cyber Kill Chain with a Threat Intelligence Platform.pdf](https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/Seven_Ways_to_Apply_the_Cyber_Kill_Chain_with_a_Threat_Intelligence_Platform.pdf)

<https://www.lockheedmartin.com/en-us/capabilities/cyber/intelligence-driven-defense.html>

בנוגע למיפוי וניתוח מתקפות ע"פ מודל ה Cyber Kill Chain של לוקהיד מרטין :

The 7 Stages of the Cyber Kill Chain

<https://kravensecurity.com/cyber-kill-chain/>

(11) בהיקף קטן מאוד: **ללא קשר לנוזקה שנבחרה : לחפש חולשה מהתקופה האחרונה**

באתר cve.org או מפרסומים אחרים .

א. אפשר לחפש ישירות מפרסומים אחרונים עדכניים באתר cve.org

ב. אפשר לחפש על פגיעיות או חולשה באתרי חדשות דוגמת <https://thehackernews.com>

ובפרט ב <https://thehackernews.com/search/label/Vulnerability>

יש לציין מספר CVE (או מספרי CVE או משפחה) ומעט רקע טכני.

(12) בהיקף קטן: **ללא קשר לנוזקה שנבחרה : לבחור שני מנגנונים טכניים**

למניעה, הגנה או למיטיגציה

ולחוסף תאור מצומצם בקצרה ע"פ הרשימה שב <https://d3fend.mitre.org>

בחרו שני מנגנונים טכניים להגנה מקטיגוריות שונות עפ המטריצה שב <https://d3fend.mitre.org>

ציינו מה השם שלהם והקטיגוריה שלהם ותמצית טכניית קצרה ביותר על מה באים להגן או איך.

(13) בהיקף קטן ומצומצם : לאתר שם של קבוצת תקיפה סינית ולפרט עליה.

12.1 שם שהוענק לקבוצה ואולי שמות אחרים שמשויכים אליה.

12.2 איזורים גיאוגרפיים וסקטורים בהם היא מתמקדת.

12.3 כלי תוכנה המשמשים אותה.

12.4 מבצע תקיפה/סייבר/חדירה בולט שאולי היתה מעורבת בו .

ניתן לראות ב:

<https://unit42.paloaltonetworks.com/tag/china>

<https://malpedia.caad.fkie.fraunhofer.de/actors>

<https://attack.mitre.org/groups>

אפשר גם לחפש בגוגל : "mitre attack groups china"

אפשר גם לחפש בגוגל : Threat Group from China

וגם ב : <https://apt.etda.or.th/cgi-bin/listgroups.cgi?c=China>

<https://apt.etda.or.th/cgi-bin/aptgroups.cgi>

וגם : <https://www.fbi.gov/wanted/cyber/apt-41-group>

14) (אופציונאלי) בהיקף קטן: לאתר שם נוזקה ל: MACOS OS (מערכת הפעלה של APPLE למחשבי Mac)

הערה: לא להתבלבל עם מערכת ההפעלה של cisco . (Cisco IOS)

(הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד).

בעדיפות לנוזקה מהתקופה האחרונה. לציין שם ומטרות פעולה.

לציין לינקים למאמרים המתארים אותה.

לציין CVEs שאולי היא נעזרת בהם.

באיזה שנה יצאה. האם ידוע איזה גרסאות של MacOS פגיעות לחולשות

אותן מנצלת הנוזקה,

האם תוקפת מחשבי MAC מבוססי INTEL או מבוססי מעבדי ARM מסוג Apple Silicon .

ראו רשימה ב:

[https://www.macworld.com/article/672879/list-of-mac-viruses-malware-and-security-](https://www.macworld.com/article/672879/list-of-mac-viruses-malware-and-security-flaws.html)

[flaws.html](https://www.macworld.com/article/672879/list-of-mac-viruses-malware-and-security-flaws.html)

[/https://www.jamf.com/blog/bluenoroff-apt-targets-macos-rustbucket-malware](https://www.jamf.com/blog/bluenoroff-apt-targets-macos-rustbucket-malware)

15) ללא קשר לנוזקה שנבחרה : לתאר מנגנון טכני שנוזקות משתמשות בו

מסוג Bring Your Own Vulnerable kernel Device-Drive

ולאתר מאמרים שמתארים את המנגנון .

שם מקובל: Bring Your Own Vulnerable Driver (BYOVD).

רקע על המנגנון : <https://attack.mitre.org/techniques/T1068>

- א. יש לחפש נוזקות שמביאות עימן (או מורידות) ומתקינות Vulnerable Device-Drive .
 - ב. יש לפרט את שם ה Driver בו נעזרת הנוזקה.
 - ג. יש להסביר מהי הפגיעות ב Driver (מספר Cve) או מהי היכולת של ה Driver אותו הנוזקה מנצלת (למשל יכולת כתיבה לזיכרון מערכת)
 - ד. יש לפרט מי הגורם שחתם דיגיטלית את ה Device Driver (אם ידוע)
- (הקלה לסמסטר זה:)יש לפרט רק את שם הנוזקה . ואת שם ה Device-Drive אותו היא מתקינה ואם ידוע מהו ה CVE המתאר את הפגיעות ב device driver .
- ניתן גם לראות רשימת נוזקות שמתקינות Device-Drive פגיע ב:

• [BlogDriver-Based Attacks: Past and Present | Rapid7](#)

<https://www.rapid7.com/blog/post/2021/12/13/driver-based-attacks-past-and-present/>

(אופציונאלי הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד) על ההנוזקה.

(אופציונאלי הקלה לסמסטר זה:) נדרש הסבר קצר מאוד ותמציתי (בלבד) על Device-Driven .

16 (אופציונאלי) **ללא קשר לנוזקה שנבחרה :**
לבחור מנגנון טכני שנוזקות משתמשות בו
(או תת-מנגנון טכני) ולאתר מספר מאמרים שמתארים אותו.

ללא קשר לנוזקה שנבחרה : לבחור מנגנון טכני שנוזקות משתמשות בו (או תת-מנגנון טכני) ולאתר מאמרים שמתארים את המנגנון .

רצוי להתסמך גם על תיאור מנגנונים (טכניקות) המתוארים ב Mitre Att&ck FrameWork ראו :
<https://attack.mitre.org/techniques/enterprise/>

ראו בהמשך פרט: תזכורות למנגנונים שראינו כבר בקורס.

יש לפרט בתמציתיות על המנגנון (בקיצור רב) .

(אופציונאלי) האם איפיינו או זיהו קבוצות תקיפה על פי נטייתן להשתמש במנגנון זה.

למשל: זיהוי של PKPLUG בהקשר של קבצים דחוסים ו DLL SIDE LOADING
https://unit42.paloaltonetworks.com/pkplug_chinese_cyber_espionage_group_attacking_asia

יש לצרף לרשימת המאמרים גם מספר מאמרים ביחס למנגנון.

יש לצרף URLS למאמרים והעתק המאמרים ואו צילום שלהם (אפשר צילום מסך נגלל) .

עדיפות למאמרים שכוללים דוגמאות קוד. (או ניתוח דוגמאות קוד)

מומלץ לחפש גם במאגרי המידע שבספריית המכון: לשים לב שבכול מאגר מידע יש להריץ שאילתת

חיפוש נפרדת עצמאית. (דורש LOGIN לאתר של המכון כלומר לפורטאל של HIT ומשם לגשת לספרייה). במידה ודרוש לכם מאמר מסוים שלא נגיש בקלות או לחיפוש מעמיק אפשר גם להעזר בספרניות היעילות שלנו : טופס לחיפוש מידע

<https://www.hit.ac.il/.upload2/files/%D7%98%D7%95%D7%A4%D7%A1%20%D7%91%D7%A7%D7%A9%D7%94%20%D7%9C%D7%90%D7%99%D7%AA%D7%95%D7%A8%20%D7%9E%D7%99%D7%93%D7%A2%281%29.rtf>

עבור ספריית המכון HIT וחיפוש במאגרי מידע : ראו <https://www.hit.ac.il/library/overview>

לבירורים, סיוע בחיפוש חומרים אקדמיים ניתן לפנות בטלפון 03-5026826

בדוא"ל ester@hit.ac.il (נא לציין במטלה את הפניות לצוות הספרייה ואת תוצאות העזרה)

מאגרי המידע הם מאגרים של מאמרים מדעים ולעיתים גם פרקים מספרים .

אבל לשים לב שיש גם הרבה פרסומים לא –אקדמיים באתרים ובטוויטרים של חוקרים עצמאיים . (בנפרד ממאמרים אקדמיים בירחונים אקדמיים)

תזכורות למנגנונים בהם משתמשים בנוזקות, שראינו כבר בקורס: (אפשר גם לבחור אחד מהם ולכתוב עליו וכמובן אפשר גם על מנגנונים נוספים שלא הוזכרו)

שיטות ל Code Injection

DLL SIDE LOADING

שיטות לגילוי ריצה במכונה וירטואלית. כלומר ANTI VM

שיטות נגד דבגרים . ונגד תהליכי דיבוג.

שימוש ב פאקרים.

מנגנוני תקשורת מיוחדים דוגמת שימוש אסימטרי באינטרנט לוויני להסתרת מיקום שרתי הפיקוד.

למשל:

<https://securelist.com/satellite-turla-apt-command-and-control-in-the-sky/72081/>

https://media.kaspersky.com/pdf/SatTurla_Solution_Paper.pdf

אפשר לראות גם רשימות טכניקות ב

[/https://attack.mitre.org/tactics/enterprise](https://attack.mitre.org/tactics/enterprise)

לדוגמה: שיטות ל Defense Evasion

[/https://attack.mitre.org/tactics/TA0005](https://attack.mitre.org/tactics/TA0005)

17) ללא קשר לנוזקה שנבחרה : לבחור מנגנון להגנה שמערכות מיחשוב משתמשות בו ולאחר

מאמרים שמתארים את המנגנון -חלק מהמאמרים מוזכרים באתר Mitre D3fend

ב : <https://d3fend.mitre.org/> בדגש על Detect-->Process Analysis

(הקלה לסמסטר זה :) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון.

18) ללא קשר לנוזקה שנבחרה : לבחור מנגנון טכני שנוזקות משתמשות בו לצורך Anti Debug

(תת-מנגנון טכני) אפשר מתוך הרשימה שב: <https://anti-debug.checkpoint.com> או

<https://www.deepinstinct.com/2017/12/27/common-anti-debugging-techniques-in-the-malware-landscape/>

וגם לחפש שימוש במנגנון בפרוצדורות המפורטות ב MITRE ATT&CK FRAMEWORK Enterprise

ולאחר מאמרים שמתארים את המנגנון או קטעי קוד שממשים אותו .

ניתן לראות הפניות למקורות ולעיתים לקטעי קוד בסוף כניסות ספיציפיות שמסתעפות מ:

<https://anti-debug.checkpoint.com>

(הקלה לסמסטר זה :) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון.

19) בהיקף קטן: ללא קשר לנוזקה שנבחרה : לבחור מנגנון טכני שנוזקות משתמשות בו לצורך

Privilege Escalation ע"פ המתואר ב Mitre ATT&CK Enterprise Matrix

(תת-מנגנון טכני) אפשר מתוך הרשימה שב: <https://attack.mitre.org/tactics/TA0004/>

ו רק לאתר מאמרים שמתארים את המנגנון (ברמת פרוצדורה) .

(הקלה לסמסטר זה :) נדרש הסבר קצר מאוד ותמציתי (בלבד) על המנגנון ופרוט שם מאמר.

20) בהיקף קטן: להביא דוגמה למקרה של החדרת נוזקה (או חומרה) ב Supply chain attacks

<https://docs.microsoft.com/en-us/windows/security/threat-protection/intelligence/supply-chain-malware>

האם ידוע באיזה חוליה בשרת האספקה אותרה ההחדרה ?

מה תאריך ההחדרה?

מהו תאריך הגילוי ואו הפרסום ?

מהי כמות המחשבים, המשתמשים והארגונים שהושפעה?

האם יש מאמר עם ניתוח טכני של הרוגלה ? האם מעורבים גם התקני חומרה או תקשורת ?

לקריאה כללית בנושא:

https://en.wikipedia.org/wiki/Supply_chain_attack

[/https://sourcedefense.com/glossary/supply-chain-attacks-2020](https://sourcedefense.com/glossary/supply-chain-attacks-2020)

<https://www.mitre.org/sites/default/files/publications/supply-chain-attack-framework-14-0228.pdf>

[/https://www.imperva.com/learn/application-security/supply-chain-attack](https://www.imperva.com/learn/application-security/supply-chain-attack)

HP laptops found to have hidden keylogger

<https://www.bbc.com/news/technology-42309371>

21) ללא קשר לנוזקה שנבחרה : בהיקף קטן: להביא דוגמה למודול RAT פופולארי (תשובות בגוף השאלה ...)

מטרה: (בצימצום) לאתר מאמרים ולהביא הפניות למודול RAT שבחרתם ולכתוב עליו בקצרה

רקע:

- כותבי נוזקות קונים או מעתיקים מודולים קיימים יעודיים לצרכי RAT Remote Access TOOL או Remote Access Trojan או Remote Administration Tool

• לדוגמה:

<https://unit42.paloaltonetworks.com/unit42-exploring-cybercrime-underground-/part-3-rat-nest>

כדאי להתחיל את החיפוש ברשימה שב :

<https://data-encoder.com/the-top-remote-access-trojans-rat-2022-list>

לחילופין אפשר גם לחפש בגוגל : list of top 10 rat malware

דוגמאות למודולי RAT פופולארים (בעבר ובהווה) : (כי כותבי נוזקות מורכבות משלבים מודלים שונים, וקונים מודול או כלי מוכן או משלבים או מעתיקים או עוטים כלי מסחרי במקום לפתח לבד)

- בעבר הרחוק: Back Orifice , Sub7
- **Poison-Ivy, JRAT, NjRAT, Orcust-RAT, CyberGate, DarkComet, DreamWare, BlackShades, NetWire. NanoCore**
- יש גם נוזקות שעוטפות ומתקינות כלים מסחריים ליגטימיים (בלי רשות מהכותבים המקוריים)
- <https://www.fortinet.com/blog/threat-research/new-campaign-uses-remcos-rat-to-exploit-victims>
- אפשר לראות רשימה לדוגמה (יחסית מיושנת, לא עדכנית) של RATS ב :
- [GitHub - rainkin1993/Remote-Access-Trojan-Database: A database of RAT collected from Internet](https://github.com/rainkin1993/Remote-Access-Trojan-Database)
- <https://github.com/rainkin1993/Remote-Access-Trojan-Database>
- <https://binaryit.com.au/types-of-remote-access-trojan-rat>
- רשימת RATS פעילים בשנת 2015 :
- <https://www.darkreading.com/perimeter/the-7-most-common-rats-in-use-today>
- אפשר לראות רשימה עדכנית ל 2018 ב :
- <https://images.squarespace-cdn.com/content/v1/5b588ac24edeca055a9e40e/1613474328744-NRD48YBVMV2M5N6YOI1E/Figure+1+--+Timeline.jpg?format=750w>
- כחלק מ :
- [A Study of Remote Access Trojans — Civilsphere \(civilsphereproject.org\)](https://civilsphereproject.org/A-Study-of-Remote-Access-Trojans)

• <https://www.civilsphereproject.org/research/a-study-of-remote-access-trojans>

אפשר לראות רשימת RATs כחלק מרשימת כלי תוכנה לתקיפה ב :

[Software | MITRE ATT&CK®](#)

[/https://attack.mitre.org/software](https://attack.mitre.org/software)

• LuminosityLink Remote Access Tool (RAT) ראו מחקר של PaloAlto Networks :
<https://unit42.paloaltonetworks.com/unit42-investigating-the-luminositylink-remote-access-trojan-configuration>

• <https://resources.infosecinstitute.com/topic/top-5-remote-access-trojans>

• <https://blog.morphisec.com/nanocore-under-the-microscope>

• <https://any.run/malware-trends/nanocore>

• <https://github.com/alphaSeclab/awesome-rat>

• ראו נוזקה סינית:

• <https://www.cisa.gov/uscert/ncas/analysis-reports/ar20-216a>

• בנוגע ליכולות של LuminosityLink Remote Access Tool (RAT) ראו:

• <https://krebsonsecurity.com/wp-content/uploads/2018/07/ll-ad.png>

• אבל גם ראו את תפיסתו של התוכניתן כותב ה RAT :
<https://krebsonsecurity.com/2018/07/luminositylink-rat-author-pleads-guilty>

בבקשה לא להוריד "דוגמיות" : (עיון רק לקבלת שמות מודולים ו שמות API, לצרכים אקדמיים בלבד)

<https://github.com/rainkin1993/Remote-Access-Trojan-Database>

[https://github.com/rainkin1993/Remote-Access-Trojan-Database/tree/master/RAT
Samples/NanoCore 1.2.2.0/Resources](https://github.com/rainkin1993/Remote-Access-Trojan-Database/tree/master/RAT%20Samples/NanoCore%201.2.2.0/Resources)

אופציונאלי: לפרט MS-Windows APIs בולטים בהם ה RAT משתמש. ראה גם רשימה בתחתית:

<https://github.com/rainkin1993/Remote-Access-Trojan-Database>

אופציונאלי: לפרט שמות נזקות וא קבוצות תקיפה שנעזרות בו .

אופציונאלי: לפרט מתי התחיל הפיתוח שלו.

אופציונאלי: לפרט האם יש לו יכולות של :

Audio

Keylogger

צילומי מסך

האם יש לו יכולות של הורדה והתקנה של תוכנות נוספות?

אופציונאלי: באיזה שפות נכתב והאם התבסס על RAT קודמים ?

אופציונאלי: האם דלף קוד מקור שלו , מתי ועי מי ? האם יש גרסאות חדישות יותר ?

אופציונאלי: מאמרים נוספים

• [blog.morphisec.com/nanocore-under-the-microscopehttps://](https://blog.morphisec.com/nanocore-under-the-microscope)

דוגמאות לחיפוש עבור תת נושא זה :

Search Steps Samples: Search google: “most common rat malware “
“ list of top 10 rat malware”

Found: <https://www.darkreading.com/perimeter/the-7-most-common-rats-in-use-today-/a/d-id/1321965>

<https://resources.infosecinstitute.com/topic/malware-spotlight-what-is-a-remote-access-trojan-rat/>

מאמרים נוספים לדוגמה :

[/https://threatpost.com/poison-ivy-rat-spotted-in-three-new-attacks/102022](https://threatpost.com/poison-ivy-rat-spotted-in-three-new-attacks/102022)

ביחס ל NanoCore :

<https://blog.morphisec.com/nanocore-under-the-microscope>

<https://success.trendmicro.com/solution/1122912-nanocore-malware-information>

<https://www.civilsphereproject.org/research/a-study-of-remote-access-trojans>

<https://medevel.com/18-os-rat-list/>

<https://github.com/Cryakl/Ultimate-RAT-Collection>

<https://www.fortinet.com/resources/cyberglossary/remote-access-trojan>

<https://www.infosecinstitute.com/resources/hacking/top-5-remote-access-trojans/>

<https://www.securitynewspaper.com/2021/09/06/top-6-remote-access-trojans-rat-used-by-russian-hackers-which-one-is-the-best-as-per-malware-analysis-experts/>

<https://medevel.com/18-os-rat-list/>

<https://www.darkreading.com/perimeter/the-7-most-common-rats-in-use-today>

<https://blog.checkpoint.com/security/july-2023s-most-wanted-malware-remote-access-trojan-rat-remcos-climbs-to-third-place-while-mobile-malware-anubis-returns-to-top-spot/>

22) דוגמה לנוזקה מסוג FileLess Malware (או bodiless)

ללא קשר לנוזקה העיקרית שנבחרה, לאתר **שם נוזקה (+מאמר עליה)** שמשתמשת ב טכניקות של FileLess Malware. (כתיבה קצרה: שם נוזקה + מציאת מאמר + לינק למאמר)

יש לפרט:

- א. שם הנוזקה
- ב. תאריך דיוח מוקדם ראשוני בנוגע לשימוש בה.
- ג. פירוט אחת מבין פקודות המערכת בהן הנוזקה משתמשת.
- ד. (בקצרה) פרוט שיטה מתקדמת (טכניקה) בה הנוזקה משתמשת (למשל שימוש ב WMIC או שימוש ב AutoIT ליצירת קוד בינארי, או למשל קריאה ל Native Api):
- ה. (בקצרה) להביא דוגמה למסע תקיפה או שימוש בנוזקה מסוג FileLess Malware (ראו <https://attack.mitre.org/techniques/T1106>)

ראו מאמרים:

- [/https://www.aquasec.com/cloud-native-academy/application-security/fileless-attacks](https://www.aquasec.com/cloud-native-academy/application-security/fileless-attacks)
- [/https://attack.mitre.org/software/S0627](https://attack.mitre.org/software/S0627)
- [/https://www.crowdstrike.com/cybersecurity-101/malware/fileless-malware](https://www.crowdstrike.com/cybersecurity-101/malware/fileless-malware)
- <https://www.cybereason.com/blog/fileless-malware>
- https://en.wikipedia.org/wiki/Fileless_malware
- <https://www.mcafee.com/enterprise/en-us/security-awareness/ransomware/what-is-fileless-malware.html>
- <https://media.kaspersky.com/en/business-security/fileless-attacks-against-enterprise-networks.pdf>
- <https://www.paloaltonetworks.com/cyberpedia/what-are-fileless-malware-attacks>
- <https://zeltser.com/fileless-malware-beyond-buzzword/>
- https://www.trendmicro.com/en_us/research/20/e/netwalker-fileless-ransomware-injected-via-reflective-loading.html

Obfuscated Files or Information: Fileless Storage : וגם

[/https://attack.mitre.org/techniques/T1027/011](https://attack.mitre.org/techniques/T1027/011)

23) תיאור נזקה שמשמשת ב WebInject

ללא קשר לנזקה העיקרית שנבחרה, לאתר נזקה פינגסית שמשמשת ב Web Inject בקצרה: לאתר את שם הנזקה וגם ניתן להעמיק ע"פ "Browser Session Hijacking" ש:

[/https://attack.mitre.org/techniques/T1185](https://attack.mitre.org/techniques/T1185)

כללית:

האם יש מידע על ה WebInject KIT שמשמש אותה (או פיתוח עצמי) ?

לחילופין ניתן לתאר נזקות שעושות שימוש רק ב FormGrabber

בנוגע ל "Black shadow" :

<https://www.ynet.co.il/digital/technews/article/hjmsk9bgr>

בנוגע ל " MuddyWater " :

https://www.gov.il/he/pages/_muddywater

https://www.gov.il/BlobFolder/news/_muddywater/he/MuddyWater_עדכון פעילות MuddyWater.pdf

בנוסף ניתן לקרוא על WebInjects ב :

<https://www.virusbulletin.com/virusbulletin/2014/10/paper-evolution-webinjects>

<https://www.malwaretech.com/2014/02/webinjects-basics.html>

[/https://www.recordedfuture.com/banking-web-injects](https://www.recordedfuture.com/banking-web-injects)

<https://defintel.com/blog/index.php/2017/10/what-are-webinjects.html>

[/https://www.welivesecurity.com/2014/10/23/evolution-webinject](https://www.welivesecurity.com/2014/10/23/evolution-webinject)

<https://www.virusbulletin.com/uploads/pdf/conference/vb2014/VB2014-Boutin.pdf>

24) בקצרה: איתור מידע על מתקפה או חולשה לתקיפת מערכת AI או אפליקציות שמבוססות על LLM.

ללא קשר לנוזקה העיקרית שנבחרה:

- א. מיצאו או הביאו שם של מתקפה או חולשה שקשורה למערכת AI או לצאבוסים דוגמת ChatGPT. למשל JailBreak בהקשר זה או אפליקציות שמבוססות על LLM.
- ב. באם ידוע: ציינו טכניקות טכניות לתקיפה.
- ג. לחילופין אפשר גם לחפש שימוש במערכות AI לתקיפת מערכות AI, בגישת GAN או Adversarial_machine_learning (יעד התקיפה: מערכות AI)
- ד. בעדיפות גבוהה לחפש/לראות גם Mitre ATLAS את ע"פ https://atlas.mitre.org/pdf-files/MITRE_ATLAS_Fact_Sheet.pdf
MITRE **ATLAS** (Adversarial Threat Landscape for Artificial-Intelligence Systems)

אפשר גם לראות את: "OWASP Top 10 for Large Language Model Applications"

<https://owasp.org/www-project-top-10-for-large-language-model-applications>

אפשר גם לראות את: <https://arxiv.org/pdf/1907.10456.pdf>

<https://jailbreaking-llms.github.io/>

https://en.wikipedia.org/wiki/Adversarial_machine_learning

<https://www.tripwire.com/state-of-security/understanding-machine-learning-attacks-techniques-and-defenses>

<https://rareconnections.io/adversarial-machine-learning-attacks>

Adversarial Attacks and Defenses in Machine Learning-Powered Networks:

A Contemporary Survey, <https://arxiv.org/pdf/2303.06302.pdf>

שימוש ב LLM למימוש תקיפות אוטומטיות:

<https://arxiv.org/pdf/2402.06664.pdf>

מיטגציות (הגנות) בשימוש במערכות LLMs (Large Language Models) :

<https://thehackernews.com/2024/02/three-tips-to-protect-your-secrets-from.html>

OWASP Top 10 for LLMs

<https://owasp.org/www-project-top-10-for-large-language-model-applications>

https://owasp.org/www-project-top-10-for-large-language-model-applications/llm-top-10-governance-doc/LLM_AI_Security_and_Governance_Checklist-v1.pdf

<https://github.com/OWASP/www-project-top-10-for-large-language-model-applications/wiki/Educational-Resources>

מניעת שימוש "זדוני" במערכות LLM :

<https://thehackernews.com/2024/02/microsoft-releases-pyrit-red-teaming.html>

<https://github.com/Azure/PyRIT>

וגם שימוש ב LLMs (Large Language Models) לצרכי הגנה:
<https://arxiv.org/html/2404.11338v1>
וגם מערכות הגנה ותקיפה אוטונומיות : תחרות מ 2016 של DARPA :
<https://www.darpa.mil/program/cyber-grand-challenge>

25) בקצרה: איתור מידע על מתקפה או נזקה שנעזרת ב יכולות AI או מערכת AI מרוחקת.

ללא קשר לנזקה העיקרית שנבחרה:

- א. מיצאו או הביאו שם של מתקפה או חולשה שנעזרת במערכת AI או בשרותי API של צאבוסים דוגמת API ChatGPT . (אין הכוונה JailBreak אלא למנגנון תקיפה שכולל היעזרות ביכולות AI) .
- ב. באם ידוע: ציינו טכניקות טכניות לתקיפה.
- ג. לחילופין אפשר גם לחפש שימוש במערכות AI לתקיפת מערכות AI , בגישת GAN או Adversarial_machine_learning
- ד. אפשרי גם שימוש במערכות AI למבצעי השפעה/תודעה או ליצירת תוכן כחלק ממיתקפה.
- ה. אפשרי גם ניסיונות של מדינות (למשל אירן) לשימוש זדוני בשרותי AI לצורך.
 - ה.1. מבצעי השפעה ותודעה בסייבר .
 - ה.2. איתור חולשות
 - ה.3. כתיבת כלי תקיפה.

למשל :

<https://thehackernews.com/2024/10/ai-powered-rhadamanthys-stealer-targets.html>

<https://www.recordedfuture.com/research/rhadamanthys-stealer-even-demigods-can-die>

<https://social.cyware.com/news/ai-powered-rhadamanthys-stealer-targets-crypto-wallets-with-image-recognition-a4c6fede>

"[The threat actors behind the Rhadamanthys information stealer have added new advanced features to the malware, including using AI for optical character recognition \(OCR\) as part of what's called "Seed Phrase Image Recognition."](#)

למשל :

<https://openai.com/global-affairs/an-update-on-disrupting-deceptive-uses-of-ai>

<https://thehackernews.com/2024/10/openai-blocks-20-global-malicious.html>

"OpenAI on Wednesday said it has disrupted more than 20 operations and deceptive networks across the world that attempted to use its platform for malicious purposes since the start of the year.

This activity encompassed debugging malware, writing articles for websites, generating biographies for social media accounts, and creating AI-generated profile pictures for fake accounts on X."

**למשל (כנקודת התחלה לא אקדמית, למידע טכני ראשוני, ממנו יש להמשיך
למידע טכני מפורט):** "הצבא האיראני משתמש ב-ChatGPT וג'מיני לפיתוח נזקקות וניהול
מבצעים"
צבאיים <https://www.calcalist.co.il/calcalistech/article/hys9d9flgl>
מומלץ לראות מאמרים של חברת Microsoft בנושא.

26 בקצרה: איתור מידע על קבוצת תקיפה בסייבר שקשורה לאירן .

מומלץ לבחור קבוצה שפעילה גם בתקופה האחרונה.
ללא קשר לנוזקה העיקרית שנבחרה:

1. מיצאו או הביאו שם של קבוצת תקיפה אירנית אחת בסייבר וצינו שמות כלים שבשימוש וארועים משמעותיים המיוחסים לה.
 2. באם ידוע: ציינו כלים, טכניקות או פרוצדורות טכניות שבשימוש.
 - ח. ציינו שמות שונים בהם מזהים את הקבוצה. (באם היא מזוהה ביותר משם אחד)
 - ט. ציינו אירועי תקיפה שמיוחסים לה.
- אתרו גם את שמה ע"פ הרשימה של Actors ב malpedia (רק באם היא מופיעה בה) .
<https://malpedia.caad.fkie.fraunhofer.de/actors>

למשל : https://malpedia.caad.fkie.fraunhofer.de/actor/void_manticore

- י. ציינו מקורות עליהם הסתמכתם. (לינקים + מאמרים)
- יא. מהם התחומים או סקטורים בהם היא התמקדה או פעלה או היתה פעילה בעבר ?
- יב. האם ידועות כתובות של אתרי טוטר / X / טלגרם המקושרים לקבוצה ? האם ידועים אתרי הדלפה שבשימוש ? האם ידועים אתרים ב DarkWeb המקושרים אליה ?

ניתן לראות רשימה עדכנית כללית של קבוצות תקיפה ומידע עליהן ב: malpedia :

[fraunhofer.de](https://malpedia.caad.fkie.fraunhofer.de/actors) (Threat Actors (powered by MISP

<https://malpedia.caad.fkie.fraunhofer.de/actors>

וגם ב mitre att&ck יש לנו רשימה ב: (ניתן לחפש בדף " Iran ")

[/https://attack.mitre.org/groups](https://attack.mitre.org/groups)

<https://attack.mitre.org/groups/G0130> / למשל להגיע ל: שפועלת מתוך אירן

https://en.wikipedia.org/wiki/Threat_actor

[/https://attack.mitre.org/groups](https://attack.mitre.org/groups)

[/https://www.sentinelone.com/cybersecurity-101/threat-actor](https://www.sentinelone.com/cybersecurity-101/threat-actor)

ניתן לחפש בגוגל: "iranian cyber group" או לחפש בעברית: "קבוצות סייבר איראניות"
אפשר להיעזר בלינקים הבאים:

"קבוצות הסייבר הפועלות נגד ישראל: מפת האיומים הגדולים" מתאריך: 21/4/2024

<https://www.israelhayom.co.il/tech/tech-news/article/15634947>

<https://www.ynet.co.il/digital/technews/article/hjmsk9bgr>

מחקרים שבהם התייחסו לזיהוי קבוצות אירניות:

[/https://www.clearskysec.com/tag/iran](https://www.clearskysec.com/tag/iran)

<https://www.clearskysec.com/wp-content/uploads/2019/06/Clearsky-Iranian-APT-group-%E2%80%98MuddyWater%E2%80%99-Adds-Exploits-to-Their-Arsenal.pdf>

<https://www.cisa.gov/topics/cyber-threats-and-advisories/advanced-persistent-threats/iran>

<https://www.calcalistech.com/ctechnews/article/r1brg1pdp>

<https://www.gov.il/he/departments/news/report021223>

<https://www.gov.il/BlobFolder/news/report021223/he/231201.pdf>

<https://www.calcalist.co.il/calcalistech/article/syrm0jlit>

<https://www.eset.com/int/about/newsroom/press-releases/research/iran-linked-oilrig-attacks-israeli-organizations-with-cloud-service-powered-downloaders-eset-research-discovers>

[/https://www.pc.co.il/featured/397302](https://www.pc.co.il/featured/397302)

[/https://www.pc.co.il/featured/397289](https://www.pc.co.il/featured/397289)

<https://www.cybercom.mil/Media/News/Article/2897570/iranian-intel-cyber-suite-of-malware-uses-open-source-tools>

<https://therecord.media/oilrig-apt34-iran-linked-hackers-new-downloaders-israel>

<https://www.recordedfuture.com/leaks-and-revelations-irgc-networks-cyber-companies>

Iran International Reveals Tehran-Based Cyber Group Targeting

Israeli Hospital Saturday, 01/27/2024 <https://www.iranintl.com/en/202401267648>

(27) אופציונאלי: בהיקף קטן: היכרות עם שיטות הזרקת קוד ב MSWindows

בקצרה:

א. בחרו את אחת השיטות להזרקת קוד ב MsWindow ופרטו את ה APIs OS בשימוש שיטה זו .

למשל ראו רשימה

<https://www.elastic.co/blog/ten-process-injection-techniques-technical-survey-common-and-trending-process>

אופציונאלי , מתקדם :

ע"פ Process Injection ב Mitre Att&ck Framework :

<https://attack.mitre.org/techniques/T1055/>

https://en.wikipedia.org/wiki/Code_injection

הזרקת קוד בלינוקס: (חלקי יש מיגוון שיטות)

<https://github.com/W3ndige/linux-process-injection>

<https://www.linkedin.com/pulse/reflective-code-injection-attacks-overview-incident-taz-wake-p8pke>

<https://www.codeproject.com/Articles/33340/Code-Injection-into-Running-Linux-Application>

<https://medium.com/@jain.sm/code-injection-in-running-process-using-pttrace-d3ea7191a4be>

כלים: MS –Detour , Frida

לחילופין ניתן לכתוב (עבור סעיף זה) על פגיעות במערכות של Apple ובפרט הזרקות קוד לדוגמה :

<https://sector7.computest.nl/post/2022-08-process-injection-breaking-all-macos-security-layers-with-a-single-vulnerability>

28) שימוש בכלי AI (עבור שאלות במטלה זו. אבל באחריות אנושית)

בקצרה:

א. בחרו 2 מתוך השאלות 12-26 והעזרו ב ChatGPT ואו גימיני של גוגל ואו במנוע perplexity.ai או קלוד לגרסאותיו כדי לנסות לקבל תשובות טובות וגם הפניות טובות למקורות.

אופציונאלי ולא נדרש עבור קורס זה:

הערה עבור כלי AI של Amzon : ניתן להירשם לשימוש בעזרת חשבון או בעזרת רישום חנימי ל Free Tier

(Amazon Q Developer is available through a Free tier) או עי AWS Builder ID

. AWS Builder ID (no AWS account required) to sign in for free

<https://docs.aws.amazon.com/amazonq/latest/qdeveloper-ug/what-is.html>

מומלץ גם לצרף שירותים ודיאגרמות והסברים טכניים.

יש לוודא תשובות מעמיקות. אין להסתפק בהסבר שיטחי או כללי .

ב. יש לפרט את הגרסה של התוכנה ואו הכלי ואו השרות ואו אפליקציות שהשתמשתם בהם.

ג. יש להרשם לשרות בגרסאות החינמיות (ואין צורך להוריד גרסאות בתשלום או מינוי פרמיום).

ד. יש לצרף לינקים נוספים ועדכניים ללימוד נושא ה Prompt Engineering

https://en.wikipedia.org/wiki/Prompt_engineering

/הנדסת_פרומפטים/ <https://he.wikipedia.org/wiki/>

וגם שימושים התקפיים (בזהירות ...):

<https://github.com/OWASP/www-project-top-10-for-large-language-model-applications/wiki/Educational-Resources>

ה. יש לחפש ולמצוא לינקים מתאימים ללימוד טכניקות לכתיבת פרומפטים שמתגברות על מיגבלות מובנות עבור הנושאים שלנו. (מאמרים, קורסים, סרטונים ב youtube ועוד)

יש לאתר לינקים הקשורים

ו. (אופציונאלי בסמסטר זה) ציינו תקיפות ו exploits למעקף חסימות מובנות ב ChatGPT.

למשל לראות: טכניקות של "משחקי תפקידים" ו Prompt Injection (יש לציין לינקים להפניות העוסקות בנושא זה) אפשר גם לנסות לשאול את ChatGPT ודומיו על טכניקות כדי לעקוף את המיגבלות שמובנות בו או בגימיני וגם לשאול את גימיני או פרפליקסיטי על עקיפת מיגבלות ב ChatGPT כולל שאלות על JailBreak

ז. (אופציונאלי בסמסטר זה) השוו איכות תשובות בין ChatGPT לבין grok ואו גימיני או claude.ai <https://www.perplexity.ai/> בנושאי השאלות אותם בחרתם.

ח. יש לשים לב להשלמות מידע עדכני משנת 2023 ומשנת 2024-2026 .
ט. בונס נוסף על שימוש ב Plugins חכמים וכלי API לעבודה מול ChatGpt או MS CoPilot (לפרט שמות גרסאות ותשובות ותועלות) (יש לפרט גרסה של ה plugin ושל הסביבה - למשל בתוך MS-WORD או בגרסת ענן או Office365)

תזכורת כללית עבור המטלה: אנחנו מאוד מעודדים שימוש בכלי AI להעמקת ההסברים !!!

בנוגע לשימוש בכלי AI ותרגום אוטומאטי :

מותר להעזר בכלי AI , אבל יש לציין את סידרת הפרומפטים בהם השתמשתם ובאחריותכם לבדוק נכונות התשובות, העובדות, ההפניות והציטוטים. להיזהר מהפניות למקורות לא קיימים. יש לבדוק קיום בפועל של מאמרים והפניות (כולל שמירת צילומי מסך) מחשש להמצאת מקורות שלא קיימים. במקרה שימוש בתרגומים אוטומאטיים יש להקפיד על מונחים מקצועיים ולא תרגום ישיר כפשוטו. אבל יש לצרף את גם את :

- א. כל צילומי המסך של סידרת הפרומפטים המשמעותיים.
- ב. כל התשובות הגולמיות מהמערכת
- ג. גם העתקי טקסט של התשובות הגולמיות (למרות שיעברו עידכון לאחר מכן ...)

לינקים: <https://www.perplexity.ai/>

<https://deepmind.google/technologies/gemini/#introduction>
<https://gemini.google.com>

מידע על מגוון צאטבוטים רלוונטיים:

<https://zapier.com/blog/best-ai-chatbot/>

29) בהיקף קטן: לאתר שם חולשה ל iPhone (הקלה לסמסטר זה: נדרש הסבר קצר מאוד ותמציתי (בלבד)).

בעדיפות לחולשה vulnerability מהתקופה האחרונה. לציין שם ותיאור כללי עפ פעולתה כמו גם מטרות מבצע /פעולה. (ריגול, כופרה וכו) לציין לינקים למאמרים המתארים אותה. לציין CVEs המקושרים אליה. לציין שמות מסיעי תקיפה או נוזקות שאולי נעזרו בחולשה וזו. לציין בעת מסעי התקיפה האם משתמשת בטכניקות של SANSBOX ESCAPE. לציין האם הנוזקת שנעזרו בה כוללות מנגנון פרסיסטנטיות (כלומר שורדות Reboot) והאם הם מסוג Zero Click.

אפשר להתחיל בלינקים הבאים או דומים להם (יש לציין לינקים שנעזרתם בהם) :

<https://www.kaspersky.com/blog/triangulation-attack-on-ios/48353>

<https://macpaw.com/how-to/most-common-iphone-viruses>

30) תנו הסבר קצר של שיטה אחת/ טכניקה להשגת "הישארות בתוך המערכת"

Persistence כלומר בחרו שיטה אחת למשל מתוך ע"פ

<https://attack.mitre.org/tactics/TA0003> /

אפשר גם לבחור שיטות אחרות.

31) הסבר קצר של שיטה אחת/ טכניקה לביצוע "סילום זכויות מקומיות

"Local Privilege Escalation"

ע"פ <https://attack.mitre.org/tactics/TA0004>

יש לבחור במפורש שיטה אחת מסוימת ולהסביר עליה. (לא די בהסבר כללי מהו סילום זכויות)

32) הסבר קצר של שיטה אחת/ טכניקה לביצוע "תנועה רוחבית" Lateral Movement

ע"פ <https://attack.mitre.org/tactics/TA0008>

יש לבחור במפורש שיטה אחת מסוימת ולהסביר עליה. (לא די בהסבר כללי מהי תנועה רוחבית)

(33) הסבר קצר של שיטה אחת/ טכניקה לביצוע "הוצאת מידע" Exfiltration
ע"פ <https://attack.mitre.org/tactics/TA0010>

(34) (אופציונאלי) הסבר קצר של שלב אחד מבין השלבים של
7 stages of the Lockheed Martin kill Chain
ע"פ https://www.splunk.com/en_us/blog/learn/cyber-kill-chains.html

(35) (אופציונאלי) הסבר מהו CVSS ובפרט מהם ההבדלים בין גרסאות 3.0 3.1 ו 4
א. מהו ארגון FIRST?
ב. מה מטרת CVSS?
ג. הסבירו רקע ושימוש <https://www.first.org/cvss>

(36) (אופציונאלי) מה החידוש במודל Cyber COBRA של לוקהיד מרטין

הסבירו מהו CYBER COBRA
בקצרה מהו החידוש ומה היתרון בשימוש של
-Contextual-OBjective-Rating
CYBER COBRA
על פני Model

Lockheed Martin kill Chain ומה ההבדל בין ניתוח עפ CVSS לבין Cyber Cobra

[https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Contextual-OBjective-Rating\(COBRA\)_FINAL.pdf](https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Contextual-OBjective-Rating(COBRA)_FINAL.pdf)

COBRA evaluates the overall severity of cyber exploitation based on the context (circumstances, setting, conditions) in which the discovered findings reside. This helps to reveal an environment's resiliency to a cyber-attack and provides countermeasures based on this data.

מטלה חלק 2 : (20%)

מטרה עיקרית: איתור קוד מקור בשפה עילית

של נוזקה או כלי RAT

או או מודול מסוים בנוזקה או POC או Exploit Code.

יש להגיש לינק לקוד מקור. לא לבחור SHELLCODE, שאינו כולל קוד מקור מלא בשפה עילית, או הסבר לניצול החולשה.

קוד מקור במטלה זו, לא קשור לנוזקה שנבחרה בחלק הראשון. (במידה ויש **גם** קוד מקור זמין לנוזקה שנבחרה בחלק הראשון, אז כן ניתן בחלק ב להתייחס שנית אליה) (מקורי שדלף או הנדסה לאחור) רקע: נוזקה היא תוכנה ולכן לרוב כתובה בשפה עילית או באסמבלר.

הערה: לעיתים קטעי קוד זדוניים ShellCode נכתבים במקום באסמבלר ישירות בשפת מכונה בינארית (או שמתפרסמים בצורה בינארית גם אם נכתבו במקור בשפת אסמבלי או בשפה עילית). גם אותם ניתן לנסות להציג בשפת אסמבלי ואז בשפה עילית.

לעיתים קודי המקור דולפים או שמפורסם קוד מקור שניתן ממנו לבנות את הנוזקה לאחר שהנוזקה עברה הנדסה לאחור וחוקרים פירסמו את קוד המקור שלה.

נוזקות מודרניות לעיתים הן מודולריות וגם תתי המודלים לעיתים הם מורכבים ומשמעותיים.

POC הינו קוד הדגמה בשפה עילית או שיטת הפעלה לניצול חולשות POC proof-of-concept

<https://www.techtarget.com/searchcio/definition/proof-of-concept-POC>

מושגים: בהקשר של חולשות : POC proof of concept

בהקשר של חולשות השם המלא הוא proof-of-concept-exploit

<https://www.pcmag.com/encyclopedia/term/proof-of-concept-exploit>

Exploit Code הוא קוד בשפה עילית או בשפת אסמבלר (או שילוב של קוד בשפה עילית וצירוף קוד מכונה בינארי) שמנצל חולשה קיימת ומדגים את הניצול שלה.

כלי RAT : מודול שנקנה בנפרד שמשלבים בתוך הנוזקה שמבצע התקנת סוכן Agent שמאפשר גישה מרחוק לביצוע פקודות (לרוב ידני אפשר גם אוטומאטית) במערכת הנגועה ראשי תיבות של:

Remote Access Tool או **Remote Administration Tool** (לעיתים כלים שפותחו מראש למטרות זדוניות ולעיתים עדיפה והתקנה נסתרת) (ללא אישור המפתחים המקוריים) של תוכנה מסחרית רגילה (דוגמת AnyDesk או TeamViewer) שעבר התאמה לשימושים זדוניים

רציונאל א: (הצדקה) כחוקרים **נרצה להכיר קודי מקור** בשפה עילית, **שבהם "נעזרים" כותבי נוזקות.** (כי כחוקרים : יותר קל לחקור ולהין נוזקה ע"י חקירת קוד מקור בשפה עילית, במקום לחקור את הקובץ הבינארי או כתחליף מקדים לחקירת הקוד הבינארי עצמו) ובאותו אופן גם קוד של מנגנונים שיועיתקו בחלקם לתוך נוזקות חדשות. בכך נקצר זמני מחקר ונקל על הניתוח.

רציונאל ב : שימוש בקוד קיים במתקפות: מתקפות רבות נעזרות בפרצות ידועות או ותיקות שאינן חדשות,

כלומר מתקפות מסוג 1Day, או nDay להבדיל ממתקפות Zero Days. מתקפות Day 1 או nDay הן מתקפות שכבר יש להן תיקונים למוצרי התוכנה הפגיעים, אבל שלקוחות לא ממהרים להתקין את העידכונים ולכן הלקוחות נשארים פגיעים זמן רב לאחר פרסום התיקונים ע"י היצרן ולכן יש חשיבות להכרת האתרים בהם מתפרסמים ה exploit code או ה POC לחולשות קיימות וידועות ומעקב שוטף אחריהם. מעקב זה יקל עלינו בשלבי הגילוי והניתוח הבאים. ואת המתקפות הללו יכולים לבצע גורמים להם יש יכולות טכניות חלשות יותר (למשל קבוצות תקיפה שאין להן יכולות למצוא לבד או לקנות חולשות ואו לפתח קוד לניצול Zero Days)

באותו אופן ניצול חולשות CVE ידועות עי נוזקות "ותיקות" .

הערה: POC ראשי תיבות Proof of Concept : קוד שמדגים את ניצול החולשה .

רציונאל ג: היכרות עם שיטות של כותבי הנוזקות שמעתיקים

מקודי מקור קיימים וגם מקוד בינארי של נוזקות קיימות ומול קיצור דרך בפיתוח (**ע"י הכותבים**) נבצע קיצור דרך **בניתוח עי החוקרים** (שגם יכירו את קודי המקור) וגם נקצר זמני מחקר .
ופרסום קוד מקור למנגנון חדש של נוזקות ,
משפיע ותורם רוחבית להרבה כותבי נוזקות.
ולכן כחוקרים מעקב שוטף על פרסום קודי מקור והיכרות עם גישות של כותבים (העתקת קוד או גניבת קוד) **יכולה** לסייע ולחסוך **בניתוח הבינארי**.

רציונאל ד. לעיתים כותבי נוזקות נעזרים בטכניקות של מחקר נוזקות ואף מבצעים איסוף רחב של נוזקות לצורך מחקר (או נעזרים בגורמים אחרים שמסייעים להם באיסוף) כדי להעתיק רעיונות חדשים מנוזקות של אחרים אל הנוזקות שלהם. ונעזרים במחקר נוזקות לשיפור נוזקות.

מטרות בתת מטלה זו:

- א. איתור קוד מקור (Source Code) של נוזקה או כלי RAT :
- קוד מקור שדלף או פורסם או שוחזר בתהליך מחקר.
- ב. מטרה משנית קטנה נוספת: איתור קוד POC או Exploit Code לניצול חולשה.(אבל בבקשה לא כזה שמכיל קוד בינארי בלבד ! בפרט לא די במציאת קוד בינארי, ללא תיעוד, שלא ידועה דרך פעולתו של הקוד הבינארי עצמו וגם לא ברורה דרך ניצול החולשה)
- (הקלות לסמסטר זה למגישים לבד: לבחור בין 2א ל 2ב)
- הערה: RAT ראשי תיבות של Remote Access Tool או Remote Access Trojan , כלומר תוכנת סוס טרויאני לשליטה מרחוק (או Remote Administration Tool).

עבור סעיף זה: ניתן גם לבחור כלי תוכנה רלוונטיים לתקיפה או קודי ניצול חולשות שדלפו מארגונים מדינתיים. וזמין ונותח הקוד מקור שלהם

לדוגמה דליפות מה CIA : [/https://wikileaks.org/ciav7p1](https://wikileaks.org/ciav7p1)

דליפות מה NSA : <https://www.lawfaremedia.org/article/catalog-snowden-revelations>

בנוסף יש גם לבחור POC או ב " Exploit קוד " לחולשות (בהנחת קיום וזמינות של POC או Exploit ידוע וקוד מקור שלו ולא רק ShellCode בינארי...) .

לאחר מציאת קוד מקור : יש לוודא שזמינים גם מאמרים שמתארים את הנוזקה או ה Exploit . ואם זמינים: אזי גם מאמרים שמנתחים את קוד המקור.

מטלה 2 : חלק א' עבור חיפוש קוד מקור של נוזקה :

כללית: יש לחפש ולמצוא מאמרים שמתארים נוזקה משמעותית ומורכבת שקוד המקור שלה (source code) דלף וזמין ושיש מאמרים שמנתחים את הנוזקה ואולי גם את הקוד שהתפרסם. (יש לצרף ולהגיש רק את רשימת המאמרים והפניה לקוד מקור)

(הקלה לסמסטר זה: רק לשמור ולהגיש את רשימת המאמרים : לא חובה להתעמק בהם).

לצרף הסבר קצר ביותר מה הנוזקה עושה(בתמציתיות).

אופציונאלי: יש לצרף רשימה של צעדי החיפוש ובהן מחרוזות מילות השאלות לחיפוש בגוגל (ושל שמות מנועי חיפוש נוספים אם השתמשתם במנועים נוספים, לדוגמה: אתרים לוקאליים של גוגל דוגמת google.ru או BING ואו מנועי חיפוש סיניים או באתרים ייעודיים או חיפוש ב טוטר) אשר הביאו אתכם לאיתור הרשימה של הנוזקות ולאיתור הקוד מקור עליו תכתבו.

למי שמשתמש בחשבונות פרטיים לחיפוש באתרי שמירת פרויקטים או אתרי שיתוף, בבקשה לפרט.

בעדיפות נמוכה: אתרי שיתוף קוד שאינם github : (תזכורת: למרבה הצער צומצם החיפוש החינמי

ב <https://pastebin.com> אפשר גם <https://pastebin.com/signup> אבל ראו גם

<https://pastebin.com/tools> ואפשר לנסות חלקית להעזר בגוגל עי חיפוש בגוגל של (למשל) :

יש אתרים חדשים שמציעים אלטרנטיבה ל pastebin :

[/https://alternativeto.net/software/pastebin](https://alternativeto.net/software/pastebin)

בעדיפות גבוהה : אפשר לחפש גם ב github (או בעזרת גוגל : על תוצאות מהאתר)

יש לשמור את הלינקים לתוצאה העיקרית. !!!! (ורצוי גם את קובץ המקור למקרה שיעלם או יחסם) .

(אופציונאלי) יש לכתוב סקירה קצרה על דרך פעולתה הטכנית של הנוזקה.

ביחס לניתוח הקוד:

עבו איזה גרסה של הנוזקה אכן זמין לנו הקוד מקור ? ביחס לאיזה גרסה ומאיזה שנה מתייחס הקוד מקור שדלף וזמין ? או קוד מקור של נוזקה אחרת ששימשה כבסיס לנוזקה זו

באיזה שפות תוכנה פותחה הנוזקה או מערכת התוכנה ?

(אופציונאלי) באיזה "כלי פיתוח תוכנה" פותחה הנוזקה או מערכת התוכנה ?

(הערה: ישנן סביבות פיתוח נוספות, בנוסף על Visual Studio ו CLyon)

(אופציונאלי) האם ניתוח הקוד טרם להבנת הנוזקה.

(אופציונאלי) האם ניתוח הקוד טרם לזיהוי היוצרים שלה ?

(אופציונאלי, הקלה עבור סמסטר זה) יש לפרט אם ואיך נעשה שימוש בטכניקות obfuscation ו

anti-debugging techniques (לימוד מתוך קוד המקור) .

(אופציונאלי) האם יש דימיון בקוד ואו בשיטות הפעולה ואו בוקטורי התקיפה לכלים אחרים שלהם או

לכלים של קבוצות אחרות או לנוזקות אחרות?

(אופציונאלי) מהו גודל התוכנה (כמות שורות , כמות מודולים, מהי ההשקעה בפיתוח בשנות אדם) ?

(אופציונאלי) האם יש הערכה למשך שנות פיתוח התוכנה ? (היסטוריה קלנדרית, במשך כמה שנים

המוצר התפתח ומהם הדורות הקודמים שלו)

(אופציונאלי) האם יש מידע מסחרי או אחר שתורם להערכה למשך שנות קיום התוכנה ?

(אופציונאלי) האם יש הערכה להיקף ההשקעה בפיתוח התוכנה ?

(אופציונאלי) האם יש הערכה למשך הפיתוח ולהיסטוריה שלה?

האם הקוד מקור השפיע על כתיבת נוזקות אחרות (או שיכלולן) שהעתיקו ממנה מנגנונים ?

(אופציונאלי) איזה גרסה דלפה ?

(אופציונאלי) כיצד התפרסמה הדליפה? מי חשף אותה ? למה ? (מי גילה את קיום הדליפה ?)

(התשובה עשויה להיות: "לא ידוע") .

(אופציונאלי) האם היה אינטרס מיוחד למפרסם , שהדליף את התוכנה והאם האינטרס ידוע ואו האם

יש השערות לגביו. ? (התשובה עשויה להיות: "לא ידוע") .

(אופציונאלי) האם יש מידע כיצד דלפה התוכנה? והאם ידעו באיזה תאריך או תקופה דלפה ?

מאיזה תאריך הפרסום ולאיזה גרסאות של התוכנה הוא מתייחס ?

(אופציונאלי) האם אותרו הכותבים המקוריים של התוכנה ?

מהן הפעילויות הנוספות שמיוחסות לקבוצה או לגוף שפיתחו אותה?

הסיבה שהמטלה השניה מצמצמת יותר הינה כי לעיתים נעשה שימוש במרכיבים קיימים מתוכנות

אחרות ובעבודה זו בפרק זה, פרט להצבעה על דמיון אין צורך להרחיב ביחס למרכיבים אחרים.

טיפ: להתחיל את החיפוש בגוגל **list of leaked malware sources git**

לחפש גוגל **leaked malware sources**

לחפש בגוגל list of leaked malware sources
טיפ חשוב: לראות רשימות ב github ולראות את thezoo....

אפשר גם לחפש את הצירוף "שם הנוזקה" + Source Code + Leaked

או אפשר גם לחפש את הצירוף "שם קבוצת התקיפה" + Source Code + Leaked

(עבור תת סעיף 2)

עבור חולשות ניתן לחפש ע"פ: POC + CVE או SOURCE CODE + POC + CVE או לחפש ב exploit-DB

דוגמה ל POC שכולל קוד מכונה בינארי אבל עם הסבר לשפת האסמבלי אוצה הוא מיצג:

<https://www.exploit-db.com/exploits/51834>

בבקשה לא לבחור POC מסוג ShellCode שיש בו רק קוד מכונה בינארי וחסר בו ההסבר למשמעות הקוד הבינארי. (הסבר עי דוגמה בשפה עילית והסבר על מה משפיע ביעד התקיפה)

במקרים של דליפות גדולות מקבוצות תקיפה (כגון Conti) ניתן לחפש קודי מקור גם במאגרים שמכילים את כל הדליפה מאותה קבוצת פשע או קבוצת תקיפה (למשל ממסמכי הדליפה מ HackingTeam האיטלקית)

כדאי להתחיל את חיפוש הקוד מקור ב:

<https://github.com/ytisf/theZoo>

<https://github.com/ytisf/theZoo/tree/master/malware/Source/Original>

הערה: הדוגמאות ב

<https://archive.org/details/malwaremuseum&tab=collection>. הן משנות ה

90 ו ה 80

עבור קודי מקור ודוגמיות: כדאי להכיר את האתרים הקשורים ל VxUnderground

(בבקשה לא להוריד דוגמיות בינאריות ולהתנהל באחריות ובזהירות, ניתן דוגמיות זדוניות בינאריות לא נדרש כאן, ובפרט להיזהר בהורדה מחשש להדבקה)

<https://www.vx-underground.org>

<https://twitter.com/vxunderground>

<https://github.com/vxunderground/MalwareSourceCode>

אפשר לראות גם את:

[GitHub - Virus-Samples/Malware-Sample-Sources: Malware Sample Sources](#)

<https://github.com/Virus-Samples/Malware-Sample-Sources>

וגם את [Malware and Virus Samples | VirusSamples.com](#)

<https://www.virusamples.com> אבל דורש רישום

אפשר לראות גם את:

<https://github.com/lleon1435/malware-leaked-sources-1>

[/https://zeltser.com/malware-sample-sources](https://zeltser.com/malware-sample-sources)

<https://github.com/lleon1435/malware-leaked-sources-1>

כדאי גם להכיר את <https://www.exploit-db.com>

דוגמה לחיפוש ע"פ שם קבוצת תקיפה :

נחפש בגוגל: " conti source code leaked "

ולהגיע למשל ל: <https://github.com/gharty03/Conti-Ransomware>

וגם מאמר ניתוח ב

<https://www.researchgate.net/publication/363690714> An Analysis of Conti Ransomware Leaked Source Codes

אפשר לחפש גם בשדות החיפוש בתוך טוטר או X (או חיפוש בגוגל על תוצאות

מטוטר) (רצוי חשבון משתמש ב X)

לדוגמה : <https://twitter.com/search?q=%23conti>

רציונאל (הצדקות) תימצות : חשיבות חיפוש קוד מקור:

זמינות קוד מקור משפיעה על שיכלול נוזקות קיימות ועתידיות ומה שיפורסם גם ישולב בנוזקות עתידיות ובגרסאות חדשות של נוזקות קיימות, ולכן כחוקרים נרצה לעקוב, כדי להכיר מראש "שיכלולים" שיועקו. (כי במהרה בתור חוקרים נפגוש את הקוד בתור תוספות או שיכלול לנוזקות קיימות בשטח.)

קוד מקור יכול לשמש כקוד התחלתי לפיתוח כלי תקיפה ואף להקמת סטריטאפ. יותר קל לנתח נוזקה כאשר הקוד מקור בשפה עילית זמין, מאשר לנסות להבין קוד בינארי (ולכן תמיד בתור צעד ראשון בניתוח קוד בינארי : נחפש,אולי קיים או פורסם קוד המקור הרלוונטי או קוד מקור לחלק מהמנגנונים או ששולב קוד, מדוגמאות למנגנונים)

בסיכום : קוד מקור זמין מהווה **קיצור דרך בניתוח** וגם **קיצור דרך בפיתוח** לכותבי נוזקות וגם לחוקרים ובודאי לא נרצה להתאמץ לנתח ולהבין קוד בינארי כאשר הקוד מקור בשפה עילית זמין (ולעיתים עם הערות ותיעוד פנימי וחיצוני).....

לעיתים גם כותבי נוזקות: מוכרים קיטים עם תיעוד להפקת הנוזקות.

מטלה 2 : חלק ב' עבור חיפוש קוד מקור ל Exploit או POC :

(תזכורת: נדרשת התנהגות אחראית וזהירה, בפרט עבור כל מה שתמצאו בתת פרק זה) .

בקצרה : מיצאו לינק למימוש POC לחולשה עפ בחירתכם.

יש לחפש POC או Exploit Code שמכיל קוד מקור אבל רצוי לא POC שפורסם רק בצורה בינארית.

הקדמה (רק עבור לימוד עצמי) הסבר מהו POC לחולשות:
<https://www.pcmag.com/encyclopedia/term/poc-exploit>
[/https://encyclopedia.kaspersky.com/glossary/poc-proof-of-concept](https://encyclopedia.kaspersky.com/glossary/poc-proof-of-concept)
[/https://encyclopedia.kaspersky.com/glossary/exploit](https://encyclopedia.kaspersky.com/glossary/exploit)

צינו את שם החולשה ומתי יצאה לשוק ואז התגלתה ואז פורסמה.

צינו באם ידוע מתי פורסם ה POC או ה Exploit לראשונה.

יש לציין את מילות החיפוש בהגעה ל POC :

דוגמה לחיפוש דו שלבי : עבור מידע על חולשה מסוימת, או כדי לקבל באופן כללי רעיונות על חולשות ששימשו בסיס למתקפות ידועות: ניתן להתחיל את החיפוש דווקא בנוזקה שהשתמשה בה או לחפש ישירות על החולשה :

למשל נתחיל בחיפוש WannaCry CVE

ולאחר מכן נחפש CVE-2017-0143 POC

אתרים מועילים לדוגמה:

<https://github.com/qazbnm456/awesome-cve-poc>

[/https://www.exploit-db.com](https://www.exploit-db.com)

וכמובן אתרים הקשורים ל VxUnderground .

[/https://vx-underground.org](https://vx-underground.org)

<https://twitter.com/vxunderground?lang=he>

<https://github.com/vxunderground> ובפרט :

<https://github.com/vxunderground/MalwareSourceCode>

דוגמה לחיפוש POC עבור חולשה : עבור חולשת Stagefright (הערה: Stagefright היא משפחה של חולשות - כלומר יותר מאחת)

נתחיל ב

[https://en.wikipedia.org/wiki/Stagefright_\(bug\)](https://en.wikipedia.org/wiki/Stagefright_(bug))

ונבחר לחפש מידע על CVE CVE-2015-1538 ומשם נגיע ללינקים האחרונים בתחתית המאמר ב

<https://nvd.nist.gov/vuln/detail/CVE-2015-1538>

ומשם נגיע למימוש ב <https://www.exploit-db.com/exploits/38124/>

(הערה: המימוש הזה ב exploit-db כולל קוד בינארי עבור shell_reverse_tcp אבל בדף זה כן יש הסבר עבורו)

בנוגע לקודי מקור עבור RAT : (כמובן ישנם עוד מאגרים רלוונטים ...)

<https://github.com/Cryakl/Ultimate-RAT-Collection>

<https://medevel.com/18-os-rat-list/>

בנוגע לדליפות קודי מקור וקוד לניצול חולשות מגופי בין, מקבוצות פשע וחברות
תקיפה בסייבר:

לדוגמה: אפשר לחפש בגוגל "conti leak source code"

<https://github.com/gharty03/Conti-Ransomware>

[https://github.com/NorthwaveSecurity/complete translation leaked
chats conti ransomware](https://github.com/NorthwaveSecurity/complete_translation_leaked_chats_conti_ransomware)

[https://www.cnbc.com/2022/04/14/conti-ransomware-leak-shows-
group-operates-like-normal-tech-company.html](https://www.cnbc.com/2022/04/14/conti-ransomware-leak-shows-group-operates-like-normal-tech-company.html)

ודליפה מ HackingTeam האיטלקית :

https://wikileaks.org/ciav7p1/cms/page_25788443.html

וגם הדליפות מגופי המודיעין האמריקאים :

לחפש "vault7" wikileaks : [/https://wikileaks.org/ciav7p1](https://wikileaks.org/ciav7p1)

וגם לחפש "shadowbrokers github"

<https://github.com/DonnchaC/shadowbrokers-exploits>

בהצלחה